

Policy-driven contextual risk evaluation in OAuth 2.0 authentication frameworks for AI chatbot-based RPA systems

Soonhong Kwon, Wooyoung Son, Jong-Hyouk Lee [✉]*

Department of Computer and Information Security & Convergence Engineering for Intelligent Drone, Sejong University, Gwangjin-gu, Seoul, Republic of Korea

ARTICLE INFO

Keywords:

AI chatbot
Authentication
OAuth 2.0 framework
Contextual risk evaluation
Sigmoid function

ABSTRACT

With the advent of smartphones, we can access internet services regardless of location. This shift in environment has led to the demand for services that can be utilized anytime, anywhere. Consequently, Robotic Process Automation (RPA) technology, which automates simple and repetitive tasks in industrial settings, is gaining significant attention. There is a growing trend to combine this with Artificial Intelligence (AI) chatbot technology to achieve full automation and handle higher-level tasks. However, when performing high-level tasks based on an AI chatbot-based RPA system, situations arise where the AI chatbot relies on the user's judgment. In such scenarios, the absence of an appropriate mechanism or technology to perform identity verification between the user and the AI chatbot exposes the system to security threats like personal information leakage and system takeover. Accordingly, this paper proposes an OAuth 2.0 integrated authentication framework utilizing a context-based risk assessment approach. This framework aims to reduce the likelihood of security threats and minimize the scale of damage caused by such threats. It achieves this by enabling access control based on the user's context while requiring the user to provide minimal information when utilizing the AI chatbot-based RPA system. More specifically, the proposed framework employs a risk assessment based on the sigmoid function, which accounts for sensitivity variations across different contexts. This approach enables sensitive adjustments to access permissions in response to contextual changes, rather than applying a fixed risk assessment. This demonstrates the framework's capability to provide a trustworthy automated work environment through appropriate access control. Specifically, the proposed risk assessment formula quantitatively analyzes sensitivity changes for each contextual variable through mathematical interpretation. Based on this, it structurally derives the correlation between risk scores and policies. Furthermore, experimental results confirm consistency between policy flow and risk assessment, such as issuing 'Full Access Tokens' in normal situations and applying Access Denied in high-risk situations. Furthermore, using data flow diagrams and STRIDE, potential security threats within the proposed framework were modeled. Simulation of actual security threats demonstrated the framework's ability to mitigate these threats, with an average latency of 9.22ms and memory usage of 64.00MB required for threat response. This empirically demonstrates that the proposed framework is a valid authentication structure capable of simultaneously achieving real-time performance, security, and lightweight characteristics even in AI-based automated environments.

* Correspondence to: Department of Computer and Information Security & Convergence Engineering for Intelligent Drone, Sejong University, Gwangjin-gu, Seoul, Republic of Korea.

E-mail address: jonghyouk@sejong.ac.kr (J.-H. Lee).

<https://doi.org/10.1016/j.compeleceng.2025.110759>

Received 6 May 2025; Received in revised form 7 September 2025; Accepted 5 October 2025

Available online 9 October 2025

0045-7906/© 2025 Published by Elsevier Ltd.

1. Introduction

With the advent of smartphones, people have gained the ability to access Internet services regardless of their location. In particular, the emergence of Internet banking has enabled users to conduct banking transactions without the need to visit a physical bank. The widespread adoption of such digital services has gradually transformed our lives, creating an environment where people increasingly expect to access services anytime and anywhere. As a result, many companies are striving to provide services that transcend time zones and national borders. At the same time, in industrial settings, there is a growing demand for technologies capable of automating manufacturing processes without human intervention.

These requirements led to the demand for 24/7 service automation, meaning “services must be provided 24 h a day, 7 days a week”. To meet this demand, Robotic Process Automation (RPA) technology has emerged as one of the most prominent solutions. RPA technology refers to the use of virtual software robots, commonly called bots, to handle time-consuming or repetitive tasks on behalf of humans. While this technology has been widely used in manufacturing plants for production purposes, it is now increasingly being adopted by businesses and public institutions to enhance operational efficiency.

However, simply using RPA technology alone does not guarantee the achievement of complete service automation. In particular, since there are users who interact with the service, automating a service requires more than just providing predetermined answers to predetermined questions. It must be able to understand the context of user requests and flexibly deliver appropriate automated services accordingly. To this end, with the commercialization of Generative Artificial Intelligence (AI) technology, AI-powered chatbots are now being integrated with RPA technology to realize fully automated services. More specifically, recent AI chatbot-based RPA services are capable of performing even higher-level tasks such as email delivery, meeting summarization, and task execution tailored to user requirements [1].

In line with this positive trend, The Business Research Company, a market research firm, has projected that the global AI-based chatbot market will grow from USD 8.6 billion in 2024 to USD 11.14 billion in 2025, achieving a compound annual growth rate of 29.5% [2]. However, as security threats targeting AI chatbots continue to emerge, ensuring their security has become essential [3–6]. In particular, in AI chatbot-based RPA systems, which automatically handle high-level tasks, it is critical to implement proper identity authentication and access control mechanisms by taking into account both the user’s context and the sensitivity of the tasks being processed.

Therefore, this paper proposes an OAuth 2.0 integrated framework that leverages context-based risk assessment methods to create a reliable working environment for AI chatbot-based RPA systems. The proposed framework enables users to access services with minimal disclosure of personal information while enforcing access control based on user context. Specifically, the framework utilizes Decentralized Identity (DID) [7] to ensure identity verification using minimal user information. Its primary goal is to assess risk based on user contextual information and task sensitivity, and to establish an environment where appropriate access rights are granted through comparison with predefined security policies, particularly for tasks involving sensitive information.

In this study, we propose an integrated authentication framework for AI Chatbot-based RPA systems that enables fine-grained, context-aware access control without directly storing users’ Personally Identifiable Information (PII). By combining DID-based self-sovereign identity with OAuth 2.0-based access control policies, the framework ensures both real-time responsiveness and robust security in high-level automation environments. The main contributions are as follows:

- 1. Integration of DID-based identity verification with sigmoid-based risk evaluation:** Leveraging user-issued DIDs, the framework enables privacy-preserving identity verification without relying on a centralized credential repository. In parallel, the sigmoid-based risk evaluation model incorporates contextual factors such as user location, access environment, time zone, and task sensitivity in real time, enabling precise control over access to sensitive tasks.
- 2. Implementation of OAuth 2.0-based adaptive access control via policy-linked token issuance:** Depending on the evaluated risk level, the framework dynamically issues access tokens with one of three privilege levels—Full Access, Limited Access, or Access Denied—and experimentally verifies consistent policy enforcement across scenarios. This design ensures semantic coherence between the OAuth authentication flow and context-aware risk assessment, while enabling fine-grained access control at the token level.
- 3. Quantitative analysis and security parameter optimization using sensitivity functions:** The proposed framework extends the sigmoid sensitivity function within the risk evaluation model to allow numerical tuning of context-specific parameters such as the inflection point (μ) and slope coefficient (k). Through mathematical derivation of Risk Assessment score gradients, we quantify the model’s responsiveness to variations in contextual attributes (e.g., location, access type, time, user behavior) and analyze the security impact of parameter adjustments in a measurable manner.
- 4. Validation of practical applicability and extensibility through real-world implementation:** A prototype system was built by integrating a Flask-based OAuth server with a RASA-powered AI Chatbot. Risk evaluation and access control results were verified under both normal and high-risk contextual scenarios. The experiments confirm that the proposed architecture delivers adaptive responses based on users’ contextual information, demonstrating its viability in domains such as finance and public services where PII protection is a critical requirement.
- 5. Mitigating Security Threats:** To analyze the security of the proposed framework, we modeled potential security threats using Data Flow Diagrams (DFDs) and Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege (STRIDE). Simulation of actual security threats demonstrated that appropriate countermeasures can minimize user impact even if real threats occur.

Table 1
Roles of key components in AI chatbot-based RPA system [9].

Component	Description
End points	An interface through which users interact with the chatbot via various channels such as voice, chat, web, and mobile.
Conversational experience	A component that controls the conversation flow along with input channels and processes user requests based on voice recognition.
NLP/AI platform	A component that analyzes user intent and understands the context of the conversation to convert it into automation commands.
Integration hub	A component that connects with external systems based on the results obtained through NLP (Natural Language Processing).
External systems	A backend system that performs automation processing for the actual tasks requested by the user.
Resolution/Feedback	A component that converts the results of task processing into chatbot responses and delivers them to the user.
Database	A database that stores data such as domain knowledge and conversation logs, which are primarily used for AI learning.
Monitoring dashboard	A component responsible for monitoring the overall system operation.

These contributions demonstrate that the proposed framework goes beyond theoretical security modeling to provide a practical, real-time security solution that combines quantitative risk evaluation with dynamic access control. In particular, it offers a foundational technology suitable for environments where security must be dynamically adjusted in response to varying contextual factors.

The structure of this paper is as follows. Section 2 describes the AI Chatbot-based RPA system and the potential authentication-related security risks within that system, and details the OAuth 2.0 concepts underpinning the proposed framework. It also highlights the main motivations and insights of this paper. Section 3 explains the proposed framework based on its architecture, message flow, and key algorithms. Section 4 analyzes the accuracy and sensitivity of the results obtained by evaluating risks and granting permissions based on calculated risk scores before issuing access tokens through the proposed authentication framework. It also analyzes how the proposed framework can respond to each security threat through security analysis based on DFD and STRIDE. Section 5 presents the limitations of the proposed framework along with future research directions, and Section 6 concludes this paper.

2. Background and motivation

2.1. AI chatbot based RPA systems

As briefly mentioned in Section 1 above, RPA refers to virtual software designed to automatically perform repetitive and rule-based tasks traditionally carried out by humans. With the emergence and widespread adoption of RPA in industrial environments, it offers key advantages such as eliminating errors commonly caused by manual human tasks and enabling faster task processing. In general, RPA systems can be classified into the following three types [8].

- **Attended RPA:** This type of RPA is mainly used in user-centered work environments, where it is executed not independently but when direct user judgment or intervention is required during task execution.
- **Unattended RPA:** This type of RPA operates independently without human intervention and is commonly used in server environments to automatically process repetitive tasks based on predetermined and fixed rules.
- **Hybrid RPA:** The Hybrid RPA model combines both Attended and Unattended RPA. In this model, when a user submits a request through the front-end interface, the request is processed by linking it to the Unattended RPA. This type is particularly utilized in AI chatbot-based RPA systems.

Since Attended and Unattended RPA types are limited to handling only simple and repetitive tasks, they are not capable of flexibly receiving and processing dynamic user requests. Therefore, recent RPA implementations have increasingly adopted Hybrid RPA. As mentioned earlier, Hybrid RPA is commonly utilized in AI chatbot-based RPA systems, enabling the system to understand user requests based on context and connect them to Unattended RPA for processing more advanced tasks. The overall architecture of the AI chatbot-based RPA system is shown in Fig. 1, and its main operational process is described in detail in Table 1.

As shown in Fig. 1 and Table 1, the AI chatbot-based RPA system begins when a user transmits a request for a specific task via an endpoint, using either text or voice input. If the user inputs text data, the system utilizes an NLP platform to examine and understand the context of the request, thereby grasping the overall intent. After determining the overall intent, the AI engine selects the appropriate business process based on pre-trained policies. Subsequently, the selected business process is transmitted to an external RPA Agent via the Integration Hub. The external RPA Agent processes the task matching the request and then converts the result into natural language, delivering it to the user in a human-understandable format. After receiving the results for their requested task, users can provide feedback. This feedback is utilized for AI training to enable continuous improvement. The overall system status is monitored via a dedicated dashboard.

Through this series of operational processes, users' high-level requests can be processed more effectively, enabling faster and more efficient task execution. This, in turn, offers significant benefits in terms of time efficiency.

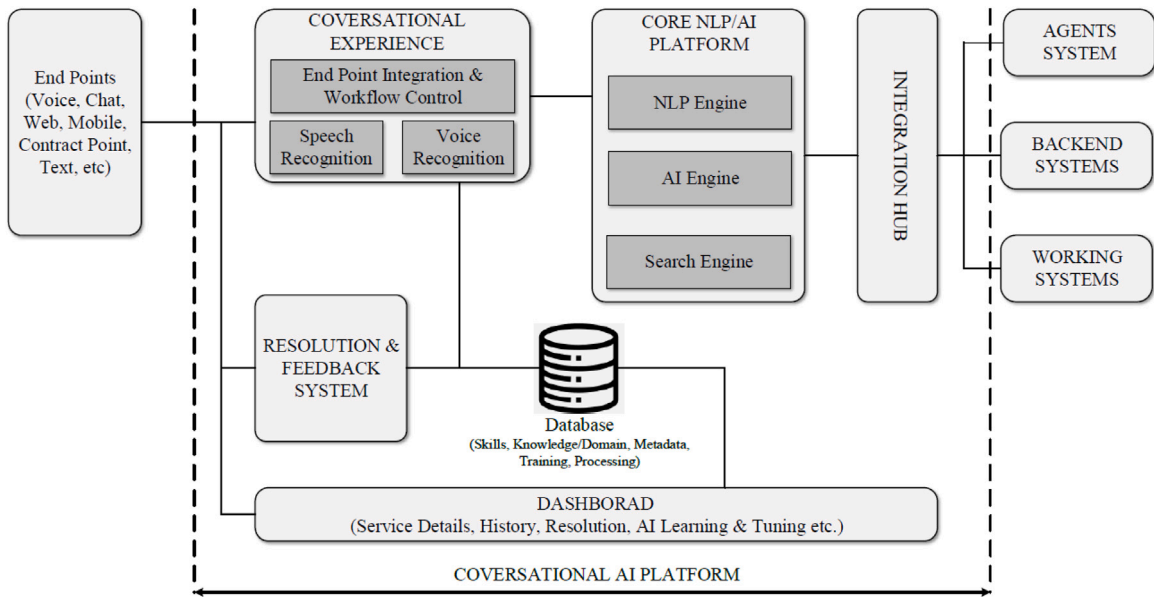


Fig. 1. AI chatbot based RPA system architecture [9].

Table 2

Types of security threats to AI chatbots.

Threat type	Description
Data leakage [11]	AI chatbots may collect sensitive information such as personal data or confidential details entered by users. This refers to situations where an attacker infiltrates the internal system of the AI chatbot, resulting in data leakage.
Prompt injection [12]	Attackers or even ordinary users may exploit AI chatbot services by manipulating inputs to induce malicious behavior. For example, by inserting specific keywords or bypassing input restrictions, attackers can force the AI chatbot to perform unintended actions.
Evasion attack [13]	AI chatbots process user inputs and generate responses, including contextual analysis of queries. Attackers may exploit this feature to carry out social engineering attacks or use it as a means to execute evasion attacks.
Malware attack [14]	Attackers can exploit vulnerabilities within the AI chatbot system to inject malware or deliver malicious links included in user inputs, leading to system compromise or further infection.
Hallucination [15]	AI chatbots may generate incorrect or misleading responses due to insufficient data learning, inadequate model tuning, or lack of testing. As a result, users may receive inaccurate or irrelevant answers to their requests or questions.

2.2. Authentication-related security risks in chatbot-driven RPA systems

Security threats to AI are continuously evolving, with various attack methods emerging, including data breach attacks, phishing attacks, and poisoning attacks [10]. These threats are becoming increasingly sophisticated over time. However, such threats have primarily been considered in the context of standalone AI models. When extending these security threats to AI chatbots, as discussed in Section 2.1, they can be further categorized and defined, as shown in Table 2.

In AI chatbot-based RPA systems, various security threats beyond those listed in Table 2 may also arise. As discussed in detail in Section 2.1, handling high-level tasks through AI chatbot-based RPA systems often requires user judgment or authentication. This indicates that security threats may occur during the authentication process between the AI chatbot and users. Table 3 summarizes the potential security threats that may arise in the user authentication process within AI chatbot-based RPA systems.

As shown in Table 3, if identity verification between users and the AI chatbot is not properly implemented in AI chatbot-based RPA systems, and access control is not clearly defined, it can have a significant impact on other connected systems. The importance of considering authentication-related security threats lies in the fact that most existing research and practices tend to focus primarily on protecting the AI model itself, rather than addressing security from a system-wide perspective. However, many system-level security threats stem from the lack of proper identity verification between the AI chatbot and users, as well as the absence of clearly defined Role-Based Access Control (RBAC) and authorization based on task sensitivity.

With the recent rapid growth of the generative AI industry, AI chatbot-based RPA systems are expected to become increasingly advanced. Accordingly, research and development efforts should focus on establishing effective access control mechanisms based on identity authentication between AI chatbots and users, in order to provide reliable and secure automation services.

Table 3

Authentication-related security threats in AI chatbot-based RPA systems [10,16].

Threat type	Description
Lack of secure user authentication mechanisms	If the AI chatbot uses weak or single-factor authentication methods for users, attackers may gain unauthorized access to sensitive business systems or data
Token reuse and session hijacking	If tokens used for AI chatbot authentication are reused or sessions are not securely managed, attackers may hijack those tokens or sessions to impersonate legitimate users
Storage of unsecured credentials	When the AI chatbot-based RPA system stores user credentials without proper protection (e.g., without encryption or in plain text), attackers may steal this information through infiltration or leaks
Lack of proper identity verification	Without proper identity verification procedures for users, attackers may impersonate legitimate users and attempt various attacks on the AI chatbot or its connected systems.
Absence of user consent or authorization verification	If there is no mechanism to verify user consent or authorization between the AI chatbot and the user, attackers may abuse this to inject malicious prompts or commands, leading to potential attacks
Excessive privilege granting	If the AI chatbot is granted excessive privileges beyond what is necessary, attackers may exploit the automated system to carry out further attacks on other connected systems

Table 4

Entity role definitions in the OAuth 2.0 authentication framework [18–20].

Entity	Description
User (Resource owner)	The entity that grants permission for an application to access its resources. The user is the actual owner of the data that the application is trying to access.
Client (Application)	An application that attempts to access the user's resources. The client must obtain permission from the user to access the resources.
Authorization server	The server that performs user authentication and, upon successful authentication, issues access tokens to the client for accessing resources.
Resource server	The server where the user's data is stored. It allows access to the resources based on the access tokens issued by the Authorization Server.

2.3. OAuth 2.0

The OAuth 2.0 authentication framework is defined in the RFC 6749 standard and is specified to operate as shown in Fig. 2 [17]. The functions of each entity are summarized in Table 4 [18–20]. As widely known, OAuth 2.0 is based on HTTP and JSON. With the recent surge in interest in zero trust, it is gaining prominence as a leading delegated authentication technology. The delegated authentication technology mentioned here refers to a technique where a user delegates their permissions to a third party, enabling that third party to exercise those permissions.

Based on the key functions per entity in Table 4, Fig. 2 illustrates the process of the most common approach within the OAuth 2.0 authentication framework: the Authorization Code Grant. The operational process in Fig. 2 is based on a simplified login functionality and is the method used when a client performs a request for resource access on behalf of the user. This operation begins with the User making a request to the client for access to or use of a resource. Upon receiving this request from the User, the client sends a request for an authorization grant code to the Authorization Server. This request message contains the client ID, redirect_url, and response_type=code data. Upon receiving the authorization code request from the client, the Authorization Server displays a login popup for user authentication. The user completes the authentication process by entering their ID and password into the displayed login popup. If this authentication process succeeds, the Authorization Server returns the authorization code to the client.

Upon receiving an authorization code from the Authorization Server, the client requests an Access Token from the Authorization Server based on that code to access the resource requested by the user. The client's Access Token request message contains the client_id, redirect_url, grant_type=authorization_code, and code. The Authorization Server verifies the key parameters included in the request message based on the authorization code and returns an access token to the client.

Upon receiving an access token from the Authorization Server, the client forwards the user's resource usage request along with the access token to the Resource Server. The Resource Server then validates the access token and returns the requested resource to the client. The client completes the process by delivering the resource received from the Resource Server to the user.

As shown in Fig. 2, the OAuth 2.0 authentication framework offers the advantage that users can access desired services or obtain resources without directly entering their credentials. Consequently, its use must be considered essential for sophisticated access control, and it ensures privacy by preventing the direct exposure of users' personal or sensitive information.

However, even for OAuth 2.0, as discussed in RFC 6819, the technology is not completely flawless. RFC 6819 analyzed the security environment based on OAuth 2.0, focusing on security threats from a protocol perspective rather than simply implementation issues [21]. The document presented three representative security threats: "Bearer Token vulnerability", "redirect-based attacks", and "client impersonation and credential leaks".

First, the vulnerability of Bearer Tokens stems from the most fundamental weakness of OAuth 2.0: Bearer Tokens can be used by any entity possessing them. This means that if an attacker acquires a Bearer Token through a man-in-the-middle attack or leakage via the Referer Header, it can lead to privilege escalation [21].

Second, redirection-based attacks are associated with the Authorization Code Grant. As shown in Fig. 2, the Authorization Code Grant is performed via URI redirection. That is, an attacker can set up a malicious site to lure users there and thereby steal the Authorization Code or access token [21].

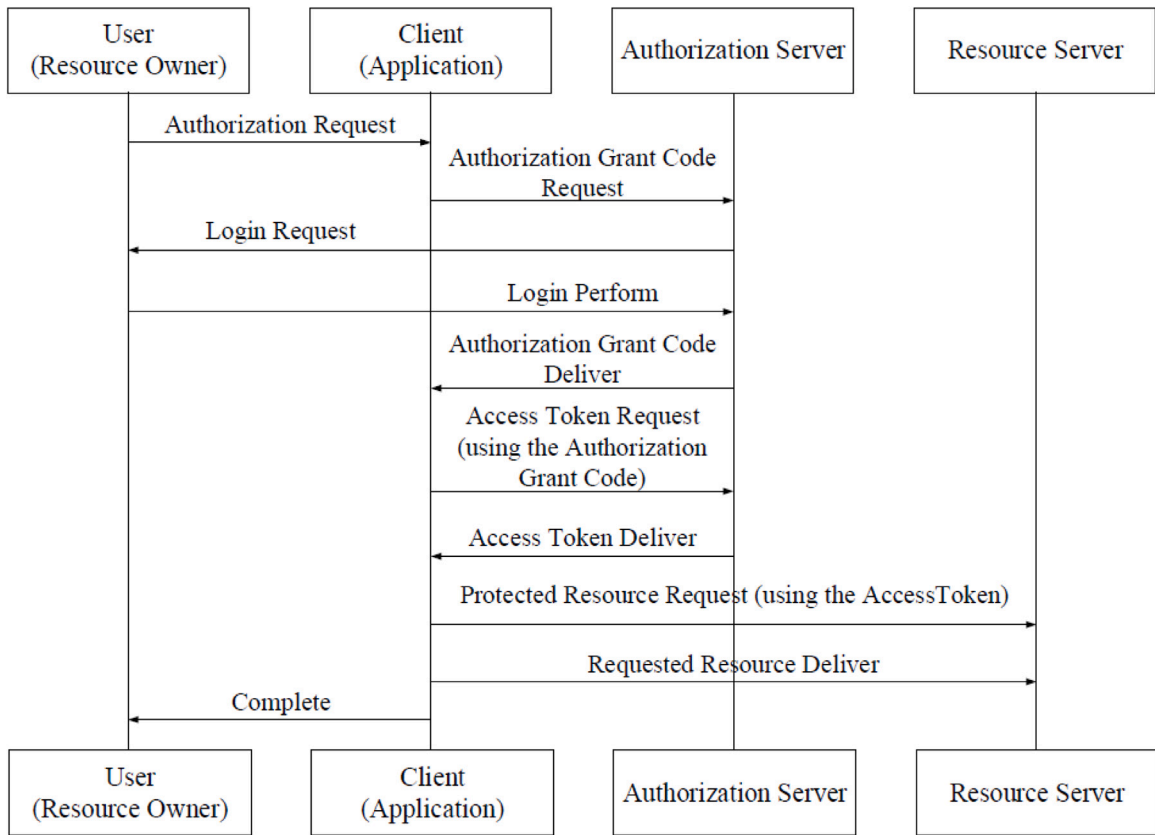


Fig. 2. OAuth 2.0 operation process [18–20].

Third, client impersonation and credential leakage represent another critical threat. Credentials such as the `client_secret` are inherently susceptible to exposure or theft during transmission. Since OAuth 2.0 does not mandate dedicated protection mechanisms for the transmission of such credentials, attackers may intercept them via man-in-the-middle attacks or craft malicious websites to steal authorization codes and access tokens [21].

In addition, recent studies have continued to reveal vulnerabilities in OAuth 2.0. Daniel Fett et al. [18] identified two new classes of attacks: the 307 Redirect Attack and the Identity Provider (IdP) Confusion Attack. The 307 Redirect Attack exploits cases where an IdP misuses the HTTP 307 status code, potentially forwarding a user's credential-bearing POST request to a malicious Relying Party (RP) without modification. Furthermore, the study demonstrated that an attacker could trick an RP into sending an authorization code to a malicious or incorrect IdP token endpoint, ultimately leading to session hijacking. The root cause of these attacks lies in the RP's inability to cryptographically verify the identity of the entity that issued the authorization code.

Furthermore, Luo et al. [22] analyzed cross-app OAuth account takeover and cross-app OAuth request forgery attacks, demonstrating that these attacks also arise due to the assumption inherent in OAuth's design: that third parties specifically, apps acting as Authorization Servers are trusted.

In other words, OAuth 2.0, due to its centralized architecture, increases the attack surface, thereby introducing various security vulnerabilities and threats. This highlights the growing need for a complementary integration with DID technologies to enhance the overall security posture.

Discussions regarding these OAuth 2.0-based security vulnerabilities have primarily focused on web applications, mobile apps, and API-based service environments. To date, systematic analysis cases targeting environments directly integrating AI chatbots and RPA have been scarcely reported. While some existing studies have addressed attempts to combine OAuth 2.0 with conversational AI agents or business automation modules for authentication and authorization, most either apply a single authentication procedure directly or remain confined to static policy-based access control. More specifically, while the method of obtaining external API access permissions via OAuth from conversational agents is widely used, it is difficult to find cases that include mechanisms for dynamically adjusting permissions based on the user's current context (location, device state, task sensitivity, etc.).

Furthermore, in AI chatbot-based RPA systems, the risk surface is elevated because such systems are capable of executing high-impact operations, including file creation/modification and system command execution. In this context, static access control alone is insufficient to ensure robust security. Although some recent studies have proposed augmenting OAuth 2.0 flows with risk assessment or situational awareness modules, these efforts remain largely conceptual or suffer from platform-specific limitations.

Therefore, this study's approach integrating context-aware risk evaluation and privacy-preserving DID-based identity verification into an OAuth 2.0 foundation within an AI chatbot–RPA environment represents a differentiated contribution. It overcomes the limitations of prior work by achieving both enhanced security and real-time adaptability in high-level automation systems.

2.4. Motivation

As mentioned in Section 1, the AI-based chatbot market is growing at an average annual growth rate of 29.5%. This positive market trend is largely driven by the emergence of Generative AI, which has been actively commercialized and widely adopted since 2022. This advancement enables the integration of traditional chatbot technology with AI, and the combination of Generative AI and chatbot technology is particularly meaningful in that it addresses the limitations of existing chatbot and RPA technologies. Traditional chatbots rely on predefined questions and answers, making it difficult to understand the context or intent behind a user's query or request.

This limitation is also one of the challenges faced by RPA systems, which are increasingly being adopted to achieve full automation in line with 24/7 operational requirements. Since traditional RPA systems are designed to handle only simple and repetitive tasks, they are now facing limitations in automating more complex and high-level tasks.

However, as mentioned earlier, the combination of AI and chatbot technologies has proven effective in addressing the two aforementioned challenges. With the growth of generative AI technology, its integration with chatbot technology has enhanced the ability to analyze the context of user inquiries or requests, thereby overcoming the limitations of traditional chatbots. Moreover, by applying this combined technology to RPA systems, the scope of automation has expanded beyond simple and repetitive tasks. It has now evolved to a level where high-level tasks, such as sending emails, organizing meeting minutes, and performing specific business operations, can also be automated.

While providing efficiency in business processing and meeting 24/7 operational requirements offers clear advantages, these benefits are primarily limited to functional aspects. As discussed in Section 2.2, AI chatbot-based RPA systems are exposed to various security threats. In particular, the absence of proper identity authentication and access control between AI chatbots and users has been identified as a critical factor that may lead to new types of security threats.

Therefore, this paper proposes an OAuth 2.0 integrated framework that enables appropriate access control based on the user's context while minimizing the amount of information required when utilizing AI chatbot-based RPA systems.

Accordingly, the proposed framework aims to achieve the following objectives as its primary goal.

Preventing Potential Security Threats in Existing Identity Authentication and Ensuring User Privacy: In terms of identity authentication, most existing services rely on authentication mechanisms using ID/PWD or Public Key Infrastructure (PKI)-based certificates. This means that centralized servers, such as Certificate Authorities (CAs), store all of the user's personal information. In other words, if an attacker successfully infiltrates a centralized server that stores users' personal data, it can lead to serious security issues, including the leakage of personal information and the disruption of all services that depend on PKI-based certificates. Furthermore, certificate-based identity authentication may result in privacy violations, as it often requires users to submit the entire certificate rather than selectively disclosing only the information required by the service provider [23]. This can lead to the exposure of unnecessary personal information. To address these issues, the proposed framework adopts DID technology, which ensures user self-sovereignty and enhances privacy by allowing users to selectively disclose only the necessary information required for authentication.

Performing Context-Based Access Control: As the importance of access control continues to grow, most existing services still primarily rely on RBAC, where access to specific services or tasks is predefined based on user roles. However, in addition to RBAC, it is essential to enforce access control based on the user's context or the sensitivity of the tasks being performed. For example, if an administrator performs sensitive operations outside of working hours through remote access, such behavior is generally considered abnormal. Therefore, the proposed framework aims to reduce the likelihood of security threats by assessing risk levels based on the user's contextual information and enforcing appropriate access control by comparing this information against predefined security policies.

Creating a Trustworthy Service Environment: The framework proposed in this paper aims to establish an efficient task processing system based on an AI Chatbot-based RPA system while simultaneously creating a trustworthy service environment. To achieve this, the proposed framework integrates the previously described DID technology with a risk assessment method based on user context. This allows users to securely prove their identity while ensuring privacy protection. Furthermore, based on a risk assessment method considering context and task sensitivity, users can safely utilize automated services anytime, anywhere. Furthermore, through security threat modeling and simulation using DFD + STRIDE, the proposed framework demonstrates its ability to mitigate security threats, minimizing damage even if actual security threats occur.

3. Proposed framework

In 2022, the commercialization of Generative AI marked the beginning of the 3rd AI boom, signaling a new era of AI advancement that is expected to continue growing steadily in the future. In this environment, many services are increasingly dependent on AI technologies to provide services anytime, anywhere, 24 h a day, 7 days a week. Accordingly, the demand for AI chatbot-based RPA systems is rapidly increasing. These systems enable AI chatbots to analyze the context of user requests to accurately understand user intent, while RPA systems automatically handle and process the corresponding tasks.

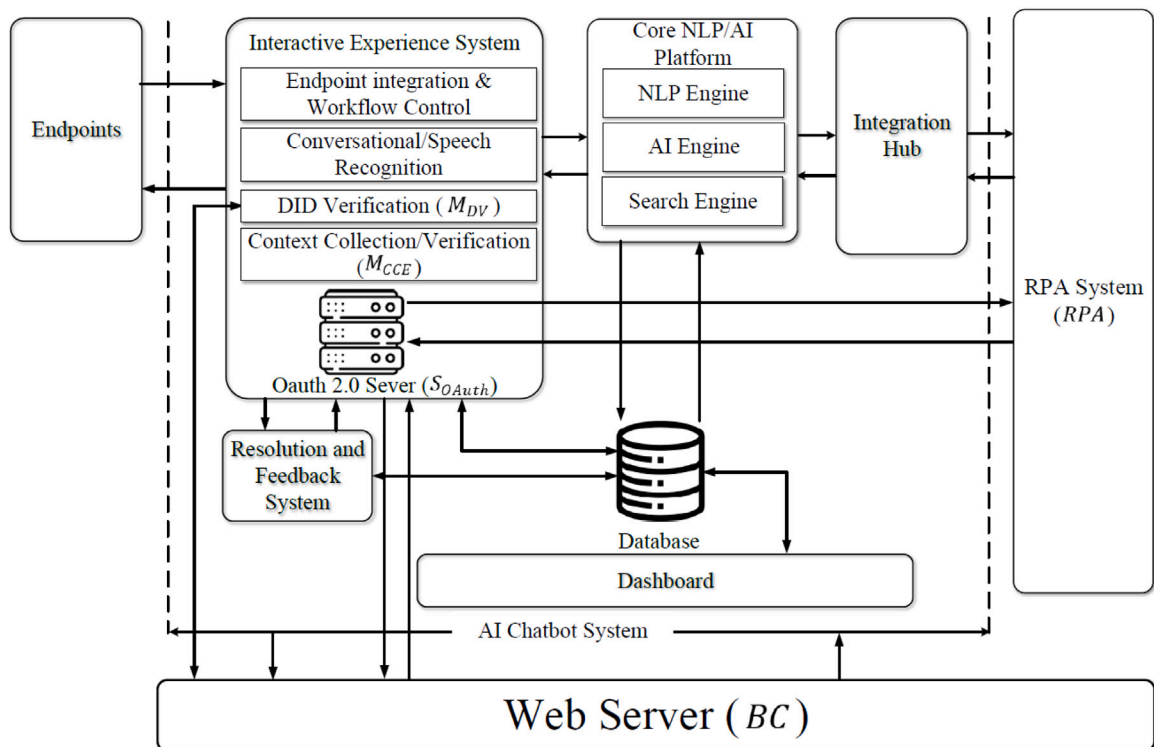


Fig. 3. Proposed framework.

However, as the demand for handling high-level tasks using the system continues to increase, human judgment becomes essential, and in such situations, access control based on proper identity authentication must be ensured. Although discussions on authentication technologies between AI chatbots and users have only recently emerged, there is still a lack of discussion on how to implement effective access control after authentication.

Therefore, Section 3 proposes an OAuth 2.0 authentication framework for AI chatbot-based RPA systems, which enables access control by evaluating risk levels based on user contextual information and task sensitivity, while ensuring user privacy through identity authentication technology based on DID technology. As shown in Fig. 3, the proposed framework consists of three main stages: the user identity authentication stage, the risk assessment stage, and the access token issuance and task execution stage.

First, the primary objective of the user identification stage is to address the limitations of traditional identity authentication methods, such as ID/PWD-based authentication and PKI-based certificate authentication. As mentioned earlier, these existing methods have critical issues, including privacy violations caused by the disclosure of unnecessary personal information and Single Point of Failure (SPoF) risks due to the use of centralized servers [24]. Specifically, if identity authentication between the user and the AI chatbot in an AI chatbot-based RPA system is performed using ID/PWD or PKI-based certificates, there is a possibility that the user's personal information could be stored within the AI chatbot. In such a case, if an attacker successfully infiltrates the AI chatbot, sensitive personal information may be leaked, or availability-related issues could occur across other services that depend on the chatbot.

Accordingly, the goal is to enable identity verification between the AI Chatbot and users in a manner that preserves user privacy and ensures that PII is not stored within the Chatbot system. To achieve this, the proposed framework adopts DIDs, a self-sovereign identity technology that addresses privacy violations and SPoF risks inherent in traditional centralized authentication mechanisms such as ID/password and PKI-based certificates. By allowing users to manage their own identity data and selectively disclose only the information required by service providers, DIDs facilitate the principle of minimal disclosure of personal information [25].

In particular, the DID:web method hosts DID Documents on a web server rather than storing them on a blockchain. During the identity verification process, the AI chatbot accesses the linked web server to retrieve the DID Document, enabling authentication with relatively high accessibility. In this process, the user provides their DID to the AI chatbot, which then accesses the corresponding web server to extract the associated public key information. Based on this information, the AI chatbot can verify the user's identity without storing any personal information, allowing identity authentication to be performed securely using only minimal necessary information.

Second, the risk assessment stage refers to the process of granting access rights by calculating the risk level based on the user's contextual information and comparing it against predefined policies. When a user requests a high-level task from an AI chatbot-based RPA system, there may be situations where the system, during the automated execution of the task, requires access to sensitive

Table 5

Notations.

Notation	Description
Cli	Client
M_{DV}	DID Verification Module
S_{OAuth}	OAuth 2.0 Server
M_{CCE}	Context Collection/Evaluation Module
RPA	Robotic Process Automation
BC	A web server that functions in the blockchain-like capacity within the DID authentication system
C_{Work}	Task to be Performed by the Client
DID_C	Client DID
Doc_C	Client DID Document
M_C	Client Message
M_{Signed}	Message Signed with Client's Private Key
K_C^{Pri}	Client Private Key
K_C^{Pub}	Client Public Key
$Authorization_{Code}$	Authorization Code
RA	Risk Assessment Score
RA_{Result}	Risk Assessment Result
C_1	Location Context
C_2	Access Type Context
C_3	Time Zone Context
C_4	User Activity Sensitivity Context
CI_1	Location Context Weight Value
CI_2	Access Type Context Weight Value
CI_3	Time Zone Context Weight Value
CI_4	User Activity Sensitivity Context Weight Value
CI_i	Context Weight Value
$W_{i,j}$	Weight Value
$Policy$	Policy
$Access_{Token}$	Access Token
ACM	Access Control Matrix
$Accuracy$	Accuracy of Appropriate Access Permission Granted
$Result$	Task Execution Result
$Sign(x,y,z)$	Signing y with x to Generate z
$Lookup(x,y)$	Querying y Based on x
$Extract(x,y)$	Extracting y from x
$Verify(x,y)$	Verifying y with x
$Collect(x)$	Collecting x
$Calculate(x,y)$	Calculating y Based on x
$Check(x,y)$	Inspecting y Based on x
$Issue(x)$	Issuing x
$Perform(x,y)$	Performing y Based on x

operations or important files, sometimes necessitating user confirmation or judgment. Typically, when users request tasks from an AI chatbot-based RPA system, these tasks may be performed within the internal environment of an organization. However, with the widespread adoption of telecommuting due to COVID-19, it is no longer reasonable to assume that all tasks are performed within a controlled internal environment. Therefore, the proposed framework enables flexible and fine-grained access control by calculating the risk level based on the user's contextual information and allowing the OAuth 2.0 server to issue access tokens in accordance with predefined security policies.

Third, the access token issuance and task execution stage follows the risk assessment stage described earlier. Once the risk level is calculated, the OAuth 2.0 server issues an access token with appropriate and situation-specific permissions based on predefined internal policies. Accordingly, even if an attacker manages to obtain a user's personal information or authentication-related data with low probability, the risk-aware access token issuance process helps to significantly reduce the likelihood of the attacker achieving their intended objectives, as the issued access token reflects the specific context of the situation.

The detailed process operates as illustrated in Fig. 4, based on the notation defined in Table 5, as described below.

- (1) Cli requests C_{Work} from the AI chatbot system.
- (2) The AI chatbot system identifies C_{Work} received from Cli through the interactive experience system and core NLP/AI platform, and requests DID_C from Cli via M_{DV} .
- (3) Cli generates M_{Signed} by signing M_C using K_C^{Pri} . This data is used to verify DID_C .
- (4) Cli sends M_{Signed} , generated in step (3), along with DID_C to M_{DV} .
- (5) M_{DV} searches internally for Doc_C based on DID_C received in step (4).
- (6) If M_{DV} cannot identify Doc_C internally in step (5), it requests Doc_C from BC based on DID_C .
- (7) BC identifies Doc_C associated with DID_C and sends it to M_{DV} .

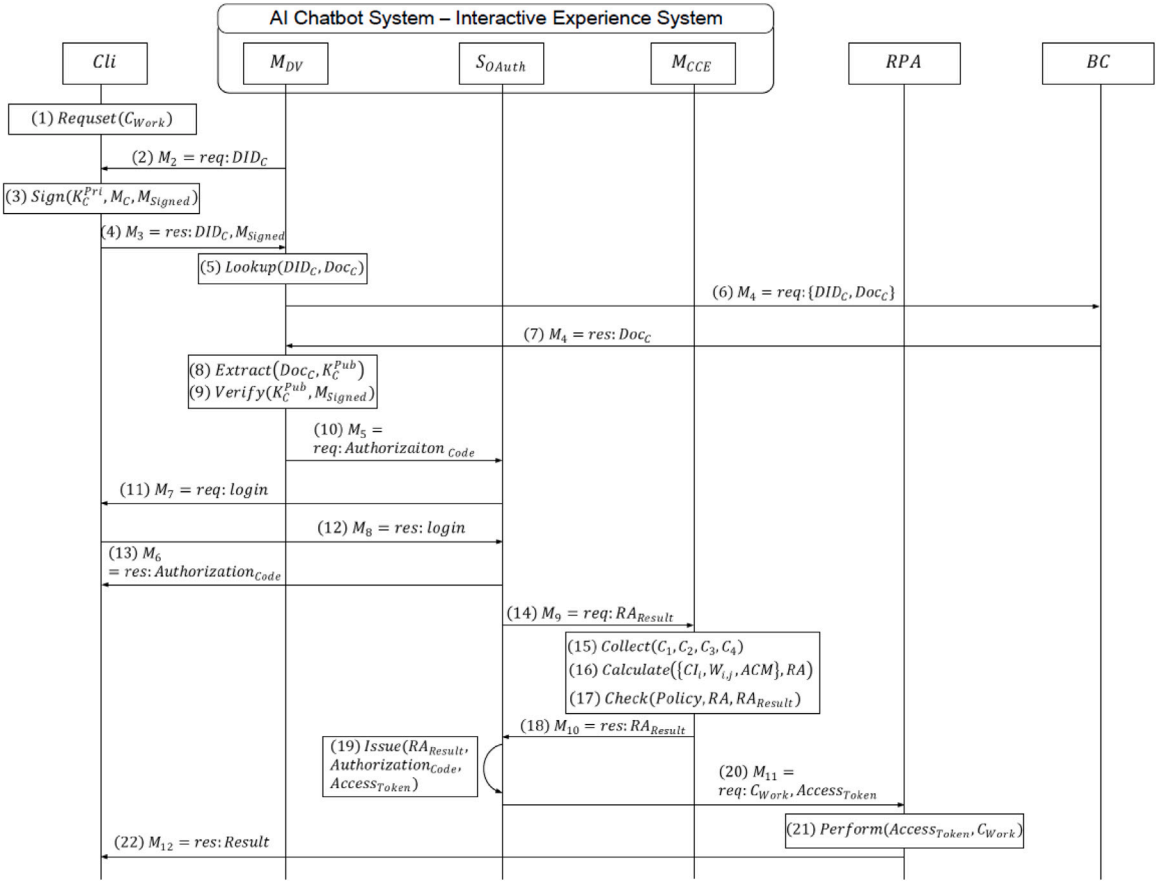


Fig. 4. Detailed operation process of the proposed framework.

- (8) M_{DV} extracts K_C^{Pub} from Doc_C received from BC .
- (9) M_{DV} verifies M_{Signed} using K_C^{Pub} extracted in step (8). If the verification is successful, DID_C is identified as valid, completing the identity verification process.
- (10) Afterward, M_{DV} requests the $Authorization_{Code}$ from S_{OAuth} .
- (11) S_{OAuth} generates a login popup and sends it to Cli , requesting a login.
- (12) Cli reviews the login popup received in step (10) and proceeds with the login process.
- (13) After confirming that Cli has successfully completed the login process, S_{OAuth} sends $Authorization_{Code}$ to Cli .
- (14) S_{OAuth} then requests the RA_{Result} from M_{CCE} .
- (15) M_{CCE} collects information on C_1 , C_2 , C_3 , and C_4 .
- (16) M_{CCE} calculates RA by performing operations on CI_i and $W_{i,j}$.
- (17) M_{CCE} checks RA calculated in step (16) against $Policy$ to determine the access control level and generates RA_{Result} .
- (18) M_{CCE} sends RA_{Result} generated in step (17) to S_{OAuth} .
- (19) S_{OAuth} issues $Access_{Token}$ based on RA_{Result} received in step (18) by using $Authorization_{Code}$.
- (20) S_{OAuth} sends $Access_{Token}$ and C_{Work} to RPA in step (19).
- (21) RPA performs C_{Work} based on $Access_{Token}$.
- (22) After completing C_{Work} , RPA delivers $Result$ to Cli .

As shown in Figs. 3 and 4, the identification process is performed based on DID. The detailed procedure of this process is further described in Algorithm 1.

As described in Algorithm 1, Cli requests C_{Work} from the AI chatbot. Before processing the requested C_{Work} , the AI chatbot requests DID_C from Cli to perform identity verification. In response, Cli sends DID_C along with M_{Signed} , which is a message signed using its private key K_C^{Pri} , to M_{DV} . M_{DV} retrieves DID_C , which is hosted on the web server and linked to DID_C , from the information received from Cli . It then verifies M_{Signed} using Cli 's public key K_C^{Pub} . If the verification fails, M_{DV} reports the result to Cli . On the other hand, if the identity verification is successful, it is confirmed that the identification process has been completed

Algorithm 1 DID-based Client Authentication

```

1: begin
2: input  $C_{Work}$ ,  $DID_C$ ,  $K_C^{Pri}$ ,  $AI\_Chatbot\_System$ 
3:  $M_{Signed} \leftarrow 0$ 
4:  $cli\_work \leftarrow C_{Work}$ 
5:  $did\_request \leftarrow M_{DV}.request(DID_C)$ 
6:  $M_C \leftarrow$  "Client's message content"
7:  $M_{Signed} \leftarrow sign(M_C, K_C^{Pri})$ 
8:  $M_{DV}.receive(M_{Signed}, DID_C)$ 
9:  $Doc_C \leftarrow request\_did\_document\_via\_web(DID_C)$ 
10:  $K_C^{Pub} \leftarrow Doc_C.public\_key$ 
11: if  $verify(M_{Signed}, K_C^{Pub})$  then
12:   print "Identity verification successful!"
13:    $K \leftarrow$  "Valid"
14: else
15:   print "Identity verification failed!"
16:    $K \leftarrow$  "Invalid"
17: end if
18: output  $K$ 
19: end

```

successfully, as shown in Fig. 5. As illustrated in Fig. 5, the authentication process based on DID:web in an HTTP environment can be observed. This represents one possible implementation example, which can be extended to an HTTP + SSL configuration. When implemented using HTTP + SSL, data transmitted during the communication process is encrypted, thereby ensuring both the integrity and confidentiality of sensitive information while effectively mitigating transport-layer threats. As a result, potential security risks associated with the OAuth 2.0 token issuance process can be significantly reduced, addressing protocol-level vulnerabilities in OAuth 2.0 as previously discussed in Section 2.3.

Once identity verification is completed, the AI chatbot performs C_{Work} requested by Cli . As described earlier, if C_{Work} involves sensitive operations or access to critical files, additional user confirmation or judgment may be required. In such cases, the user's contextual information is used to assess the risk level, and a legitimate access token is issued by the OAuth 2.0 server based on predefined internal policies. This allows the AI chatbot to perform the requested tasks with appropriate access rights according to the specific situation. The detailed process of this procedure is described in Sections 4.1 and 4.2.

Accordingly, the proposed framework enables identity verification to be performed based on minimal information using DID:web, as defined in Section 2.4, while preventing the storage of users' sensitive or authentication-related information within the AI chatbot. Furthermore, by performing risk assessment based on the OAuth 2.0 authentication framework and comparing the results with predefined internal policies, the framework aims to minimize potential damage. Even if a malicious attacker obtains the personal information or identity authentication data of legitimate users, the framework prevents the attacker from performing unauthorized actions by ensuring that access rights are granted only in accordance with the specific situation.

4. Analysis

4.1. Numerical analysis

In the proposed system, the reliability of using the AI chatbot-based RPA system is ensured by evaluating the risk based on user context, thereby achieving appropriate access control for specific tasks and granting access rights through comparison with predefined policies. To achieve this, clear context-based risk assessment criteria were established. In Section 4.1, the formula for RA based on the Sigmoid function is derived. Additionally, the sensitivity of RA to contextual changes is evaluated to verify how effectively the system can respond to even minor changes in context.

4.1.1. Risk Assessment (RA) function

The risk assessment phase corresponds to Step (18) in Fig. 4, following Step (14). This process begins when S_{OAuth} requests RA_{Result} from M_{CCE} . When M_{CCE} requests Cli for C_{Work} , it collects the context information (C_1, C_2, C_3, C_4) stores it in JSON format, and subsequently, based on the contents of the JSON file, computes RA according to Eq. (1) by utilizing CI_i , $W_{i,j}$, and ACM .

$$RA = ACM \times \sum_{i=1}^4 CI_i \left(\sum_j \varphi(W_{i,j}) \cdot P_{i,j} \right) \quad (1)$$

First, in Eq. (1), ACM was introduced to reflect the overall importance of policies, incorporating items such as policy priority and task sensitivity. Additionally, CI_i represents the overall importance of the i th context, while $W_{i,j}$ adjusts sensitivity according to specific types within CI_i , indicating the influence of detailed contexts. $\varphi(x)$ is a sensitivity response function based on the Sigmoid

```

AI Chatbot server is running on http://localhost:3000
Received DID: did:web:soonding.github.io:client_did
Received message: Client's message content
Received signature: 0xcf3624949962c626af09d0eabe966043f33b9e0206286f53b8c359a9ed44be4165c8e
cb0a9f78c1438da9a1a76613d8579d83536920205de26a70064302f9c921b
Resolved DID Document: {
  "@context": "https://www.w3.org/ns/did/v1",
  "id": "did:web:soonding.github.io:client_did",
  "verificationMethod": [
    {
      "id": "did:web:soonding.github.io:client_did#owner",
      "type": "JsonWebKey2020",
      "controller": "did:web:soonding.github.io:client_did",
      "publicKeyJwk": {
        "kty": "EC",
        "crv": "secp256k1",
        "x": "uXyY0mD0+T66HiXRID8FT1UK/GL9BebFA3XheVRVjgI=",
        "y": "J2drRXgjdZRYtidY397TmQQmwUtduaUvgIcsRKXq4bA="
      }
    }
  ],
  "authentication": [
    "did:web:soonding.github.io:client_did#owner"
  ],
  "assertionMethod": [
    "did:web:soonding.github.io:client_did#owner"
  ]
}
Message hash (server): 0f12c782d2250fd3ffdf8ea1a03e5a784e72ef34079a9faa80ec39423eb65c2d
Recovered publicKey: 0xb97c98d260f4f93ebale25d1203f054f550afc62fd05e6c50375e17954558e022767
6b457823773458b62758dfded3990426c14b5db9a52f80872c44ac6ae1b0
Expected publicKeyX: b97c98d260f4f93ebale25d1203f054f550afc62fd05e6c50375e17954558e02
Expected publicKeyY: 27676b457823773458b62758dfded3990426c14b5db9a52f80872c44ac6ae1b0
Identity Verification Completed!!

```

Fig. 5. Cli identity verification screen based on DID:web.

Table 6
Component definition.

Component	Meaning	Reference basis
ACM	Importance of overall policy	Reflects the role of the task requestor, such as role, and task priority
CI_i	Importance of the i th context	Used as a reference for the overall context of the system
$W_{i,j}$	Impact of CI_i on the i th context	Adjusts the sensitivity of each action based on its nature
$\phi(x)$	Sensitivity response function based on the Sigmoid function	Ensures the sensitivity change in RA reacts sharply within predefined system boundaries
$P_{i,j}$	Used to check whether the specific sub-context has been detected (0 or 1)	Takes a value of 0 or 1, depending on whether the sub-context has been detected

function. The Sigmoid function was used to ensure that changes in RA 's sensitivity respond sensitively within predefined system boundary intervals. $P_{i,j}$ is an item to confirm whether the specific context was actually detected, taking values of 0 or 1. The components constituting Eq. (1) and their respective meanings can be found in Table 6.

ACM is an item to define who can access each resource and task in the system with what authority, and since it is a matrix structure security policy model, it can be seen that the higher ACM , the higher the sensitivity of the task. In order to perform context-based risk assessment, which is the main function of the proposed system, the role of the user who requested the task, the target resource of the task, and the task type should be considered for the AI chatbot-based RPA system. When introducing ACM that considers both the role and task type of the user who requested the system to perform the task, the RA that introduced this can be expected to reflect both the task situation and task sensitivity of the proposed system. Tables 7, 8, and 9 represent the role of the task request user used in ACM calculation, the task target resource, and the weight of each task type, W_R , W_{Res} , and W_P , and based on this, the final ACM can be derived through Eq. (2). This confirms that in the case of ACM used to derive RA of the proposed system, security sensitivity can be separately managed for the role of the user who requested the task, the resource of the requested task, and the right to perform it.

$$ACM = W_R \cdot W_{Res} \cdot W_P \quad (2)$$

Table 7

Weight values by role.

Role	Weight value (W_R)
Regular user	0.5
External worker	0.7
Administrator	0.9

Table 8

Weight values by resource.

Resource	Weight value (W_{Res})
External public documents	0.1
Internal public documents	0.5
Customer database	0.9

Table 9

Weight values by permission.

Permission type	Weight value (W_P)
Read	0.3
Write	0.6
Execute	0.9

Table 10

Evaluation criteria used in RA assessment.

Context list	Weight value	Sub-context list	Weight value
Location information	CI_1 (0.43)	Internal	$W_{1,1}$ (0.69)
		External	$W_{1,2}$ (0.75)
Access type	CI_2 (0.52)	Internal access	$W_{2,1}$ (0.53)
		Original access	$W_{2,2}$ (0.57)
Time zone	CI_3 (0.33)	Working hours	$W_{3,1}$ (0.41)
		Non-working Hours	$W_{3,2}$ (0.44)
User activity sensitivity	CI_4 (0.6)	General tasks	$W_{4,1}$ (0.30)
		Sensitive tasks	$W_{4,2}$ (0.32)

For CI_i , which represents the overall importance of the i th context, it can be classified based on factors such as location information, access type, time zone, and user activity sensitivity. The evaluation criteria used in RA evaluation for $W_{i,j}$, which indicates the sensitivity according to the detailed type within each CI_i , are shown in Table 10.

As mentioned earlier, $\varphi(x)$ is based on the Sigmoid function. The Sigmoid function, which is one of the most widely used activation functions, plays a crucial role in various fields of science and engineering. It is modeled similarly to the way the human brain works and offers the advantage of probabilistic interpretation. By converting the input value to a real number between 0 and 1, the Sigmoid function provides an output that can be easily understood probabilistically. This makes it particularly useful in applications such as logistic regression and reinforcement learning, which have seen widespread use in recent years [26].

This study also considered various alternative activation functions such as Tanh, ReLU, and Softmax. However, the Softmax function, which calculates probability distributions through relative comparisons between input values, was deemed unsuitable for risk assessment scenarios requiring binary judgments based on a single threshold [27]. Furthermore, the Tanh function has a wide output range from -1 to 1 and is centered at 0 . This characteristic reduces the intuitive interpretability for threshold judgments based on security policies and was deemed insufficient for performing probabilistic analysis [28]. The ReLU has the limitation that its output is fixed for inputs at or below zero, making sensitivity adjustment impossible [29]. It particularly fails to provide continuous response in areas requiring actions based on security policy thresholds.

In contrast, the Sigmoid function offers the advantage of fine-grained sensitivity adjustment around a single decision boundary, with output values ranging between 0 and 1 , thereby providing a probabilistic interpretation of risk evaluation outcomes. This characteristic enables intuitive interpretation and policy-driven adjustment of risk scores. Notably, security administrators or system operators can explicitly define the sensitivity threshold (μ) and steepness coefficient (k), enhancing both the applicability and flexibility of the model in real-world operational environments. For these reasons, the Sigmoid function was determined to be the most suitable alternative for the proposed system.

The Sigmoid function is represented by Eq. (3), and its graph is shown in Fig. 6 [30].

$$f(x) = \frac{1}{1 + e^{-x}} \quad (3)$$

In the proposed system, RA is used to evaluate risk based on context. When a high risk is derived from the situation, an immediate response must be triggered to prevent the AI chatbot-based RPA system from performing the task. Therefore, it is necessary to

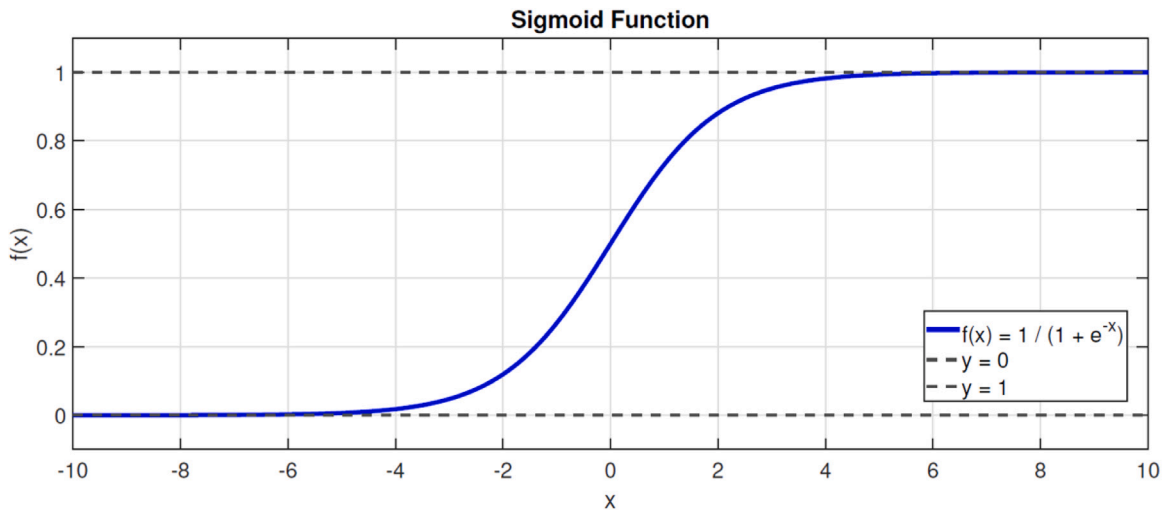


Fig. 6. Graph output type of the Sigmoid function.

Table 11

Threshold and sensitivity combinations based on contextual characteristics.

Context characteristics	Basic value (μ)	Sensitivity (k)	Judgment criteria
CI_1	0.6	10	Considered risky when external access exceeds this value
CI_2	0.55	12	Considered extremely risky without VPN or for external connections
CI_3	0.7	6	Monitoring work hours and user activity
CI_4	0.5	15	Immediate response required for sensitive tasks

establish a threshold value that responds sensitively to the RA -derived value and triggers an immediate response based on that threshold. As shown in Fig. 6, the Sigmoid function has the largest slope at $x = 0$, where a rapid change occurs. However, in the general Sigmoid function, the criterion at $x = 0$ is fixed, and there is no coefficient that reflects the sensitivity intensity. Therefore, for RA , which determines sensitivity based on context in the proposed system, it is essential to derive a function with extended parameters based on the Sigmoid function.

Accordingly, the sensitivity response function $\varphi(x)$, based on the Sigmoid function, is derived as shown in Eq. (4). In this function, the parameter k is a variable that adjusts the slope, while μ is a variable that sets the center value, which serves as the risk reference point. Fig. 7 clearly illustrates the difference between $\varphi(x)$ and the standard Sigmoid function.

$$\varphi(x) = \frac{1}{1 + e^{-k(x-\mu)}} \quad (4)$$

As shown in Fig. 7, in the extended Sigmoid function used for RA , the risk judgment value changes rapidly around μ . This point serves as the reference for determining whether $W_{i,j}$ value is classified as “dangerous”, and acts as the “cut-off” that defines the policy’s sensitivity. Additionally, as illustrated in Fig. 7, it can be observed that the slope near μ is steeper in the graph with $k = 15$ compared to the one with $k = 3$. This indicates that k value is a variable that controls how sensitively the security policy reacts to changes in risk.

As shown in Eq. (1), k and μ can be adjusted to reflect the characteristics of the situation based on CI_i . Examples of different combinations of these two parameters, tailored to the characteristics of CI_i , are provided in Table 11.

After deriving RA using the formulas described above, access rights are determined based on the risk threshold θ , which is predefined according to system policies. Then, by calculating final RA_{Result} through Eq. (5), the system can issue the corresponding access token accordingly.

$$RA_{Result} = f(RA, \theta) = \begin{cases} \text{Full Access} & \text{if } RA < \theta \\ \text{Limited Access} & \text{if } RA = \theta \\ \text{Access Denied} & \text{if } RA > \theta \end{cases} \quad (5)$$

Thus, RA proposed in Section 4.1.1 integrates various user context factors in a systematic manner and incorporates a Sigmoid-based parameter adjustment mechanism into the sensitivity response function $\varphi(x)$. This approach enables the system to quantitatively and dynamically respond to changes in contextual situations with high sensitivity. In particular, the use of k and μ parameters allows for dynamic sensitivity adjustment, enabling flexible configuration of response thresholds according to changes in the system environment or security policies. As a result, the proposed method provides a higher level of precision and adaptability compared to traditional static, policy-based access control mechanisms.

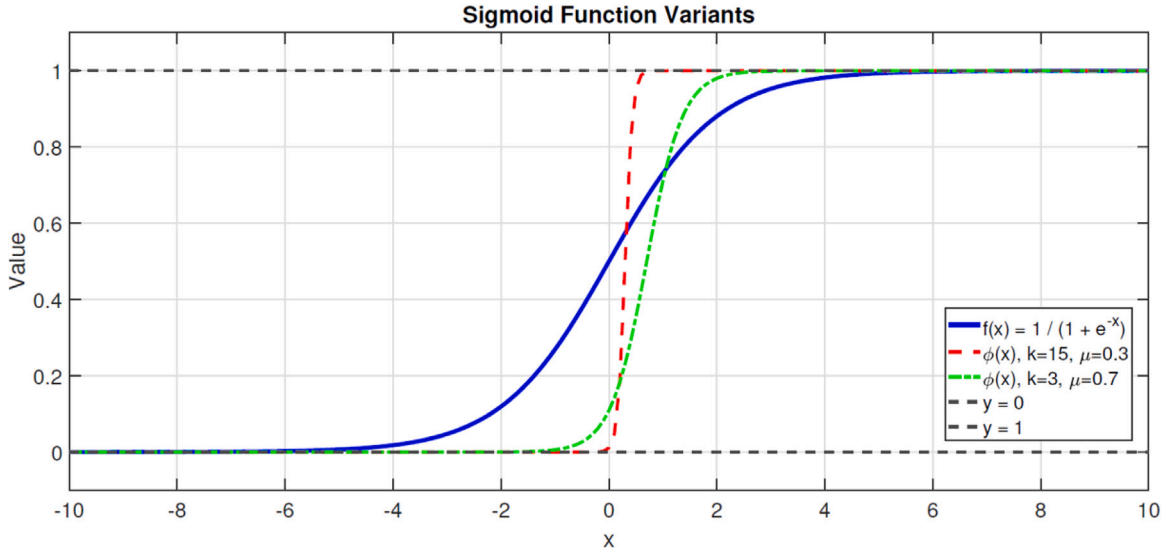


Fig. 7. Graph output type of the Sigmoid function based on threshold and sensitivity changes.

In addition, by setting θ based on RA result value, access rights can be more precisely classified, enabling differentiated security responses according to varying situational contexts, rather than relying on a simple binary allow/deny policy. In other words, based on the proposed RA function, it can be confirmed that the system is capable of simultaneously ensuring both the efficiency of task automation and the reliability of security. This is achieved by performing risk-based access control that dynamically reflects real-time contextual changes during the AI chatbot-based RPA task execution process.

It is important to note, however, that the standard Sigmoid function used in this analysis exhibits a saturation region in which sensitivity sharply decreases as the input approaches extreme values. In such cases, the output asymptotically converges to 0 or 1, resulting in diminished responsiveness to further input changes. This characteristic may pose limitations in environments where contextual changes occur continuously or where boundary conditions shift frequently, potentially hindering fine-grained policy enforcement near decision thresholds.

Nevertheless, the extended $\varphi(x)$ function proposed in this study – based on the Sigmoid formulation – allows for flexible adjustment of contextual sensitivity through the tunable parameters μ and k . This adaptability makes it well-suited for real-time response requirements in AI-driven authentication environments. Future work will explore the incorporation of dynamically adjustable sensitivity functions based on policy conditions, with the goal of further enhancing the practicality and scalability of the proposed system.

4.1.2. RA sensitivity to context changes

Section 4.1.2 aims to mathematically analyze how subtle changes in input context factors affect RA , based on the risk assessment formula presented in Section 4.1.1. This analysis seeks to quantify the system's responsiveness to changes in user context and to explain the core operational characteristics of sensitivity-based access control.

Specifically, by deriving the sensitivity of RA with respect to various user context elements, it becomes possible to quantitatively evaluate the question: “To what extent does the output (RA) change when there is a slight change in the input (CI_i or $W_{i,j}$)?” This rate of change can be mathematically defined through differentiation, and the resulting RA sensitivity with respect to changes in context is expressed as Eq. (6), based on the previously defined RA formula in Eq. (1).

$$\frac{d(RA)}{d(CI_i)} = ACM \times \sum_j \varphi(W_{i,j}) \cdot P_{i,j} \quad (6)$$

The parameters used in Eq. (6) are identical to those defined in Table 10 of Section 4.1.1. In this context, $\varphi'(x)$ represents the derivative of the extended sigmoid function. Since $\varphi(x)$ serves as the sensitivity response function, its derivative, $\varphi'(x)$, indicates the sensitivity slope — that is, the rate at which sensitivity changes in response to variations in the input value.

Furthermore, since not only changes in the overall context but also the responsiveness of specific contextual factors ($W_{i,j}$) play a critical role, Eq. (7) presents the result of differentiating $W_{i,j}$ based on Eq. (6) to extend the definition of the sensitivity gradient to include these factors. Consequently, this result corresponds to the Risk Sensitivity Gradient (RSG), which is the key metric we aim to derive in Section 4.1.2.

$$RSG = \frac{d^2(RA)}{d(CI_i) d(W_{i,j})} = ACM \cdot \frac{d}{d(W_{i,j})} (\varphi(W_{i,j}) \cdot P_{i,j}) \quad (7)$$

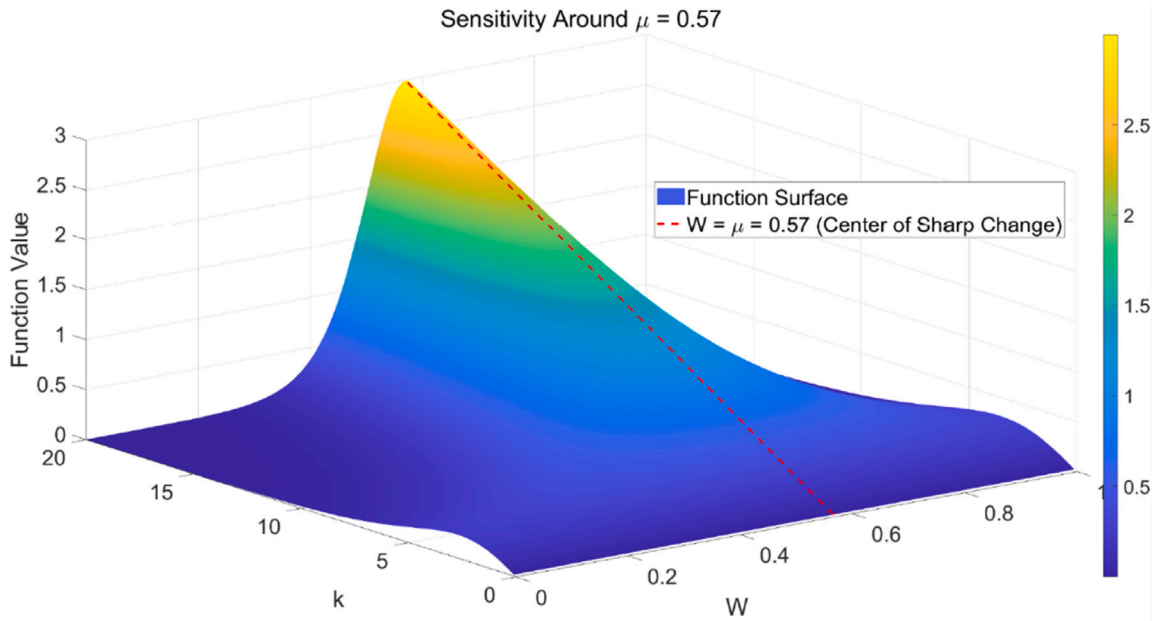


Fig. 8. Variation pattern of RSG according to weight and sensitivity.

At this point, since $\varphi(x)$ follows the same formula as presented in Eq. (4), when x is substituted with $W_{i,j}$, the result of differentiating $\varphi(W_{i,j})$ is derived and expressed as Eq. (8).

$$\frac{d\varphi(W_{i,j})}{d(W_{i,j})} = k \cdot \varphi(W_{i,j}) (1 - \varphi(W_{i,j})) \quad (8)$$

Accordingly, the final RSG , derived by applying Eqs. (7) and (8), is expressed in Eq. (9).

$$RSG = \frac{d^2(RA)}{d(CI_i)d(W_{i,j})} = ACM \cdot P_{i,j} \cdot k \cdot \varphi(W_{i,j}) (1 - \varphi(W_{i,j})) \quad (9)$$

Based on Eq. (9), when μ is set to 0.57, the variation pattern of the RSG with respect to the variables W and k - where W is used as a representative example of $W_{i,j}$ is illustrated in Fig. 8.

Fig. 8 visually illustrates how the system's sensitivity increases as the input variable $W_{i,j}$ approaches the fixed reference point μ . This behavior is based on the property of the sigmoid function, where $\varphi(W_{i,j})(1 - \varphi(W_{i,j}))$ reaches its maximum at $W_{i,j} = \mu$. Furthermore, as the value of k increases, the peak of the curve becomes sharper, and the sensitivity response becomes more concentrated around $W_{i,j} = \mu$. This visual representation clearly demonstrates that k serves as a key parameter that simultaneously controls both the intensity and the range of the system's sensitivity.

Through this mathematical and visual analysis, it can be confirmed that the proposed system provides a quantitative sensitivity control mechanism capable of responding immediately to even subtle changes in input values. In particular, the RSG is expected to function as a key tool for enhancing the agility and precision of AI chatbot-based RPA systems. By quantitatively identifying the impact of changes in user context factors on access control decisions, RSG provides a solid foundation for the flexible adaptation of access control policies in response to dynamic environments.

4.2. Performance analysis

To illustrate how access control is enforced based on the risk assessment process within the proposed framework, an AI chatbot-based RPA system was implemented using the RASA framework, in conjunction with a Flask-based OAuth 2.0 server. The risk assessment process calculates the risk level by integrating three key factors: context importance, detailed situation sensitivity, and the sensitivity response function, as described in Section 4.1. In particular, the sensitivity response function is applied using Eq. (1) from Section 4.1.1. Accordingly, the experiment was conducted under two different scenarios: the first scenario involved performing a risk assessment for a high-risk situation, while the second scenario involved performing a risk assessment for a normal situation.

To conduct the experiment under a high-risk scenario, it was assumed that the user requested a sensitive task to the AI chatbot outside of regular working hours via remote access from an external location. In this scenario, the risk threshold was predefined as 0.22 according to internal policy. The experiment demonstrated that access in a high-risk situation can be effectively blocked by restricting access when the calculated RA exceeds the threshold value of 0.22. As shown in Figs. 9 and 10, it was confirmed that access was denied because the calculated RA in this scenario was 0.2988, exceeding the predefined threshold.

Table 12

Risk contribution analysis results for each contextual factor in a high-risk scenario.

Context	CI_i	$W_{i,j}$	$\varphi(W_{i,j})$	Contribution ($CI_i \times \varphi(W_{i,j})$)
Location	0.43	0.75	0.8176	0.3516
Connection	0.52	0.57	0.5597	0.2911
Time	0.33	0.44	0.1736	0.0573
Sensitivity	0.60	0.32	0.0630	0.0378
Total	–	–	–	0.7378

```

2025-04-10 04:57:38 INFO      root - Rasa server is up and running.
Bot loaded. Type a message and press enter (use '/stop' to exit):
Your input -> /request_rpa_job
Requesting RPA job execution with OAuth 2.0 token...
Access Denied
RA Score: 0.2988 (above threshold)
Risk Contribution Detail:
- location: CI=0.43, W=0.75,  $\varphi$ =0.8176, contribution=0.3516
- connection_type: CI=0.52, W=0.57,  $\varphi$ =0.5597, contribution=0.2911
- time: CI=0.33, W=0.44,  $\varphi$ =0.1736, contribution=0.0573
- activity: CI=0.60, W=0.32,  $\varphi$ =0.0630, contribution=0.0378
Response: {
  "error": "Access denied due to high risk",
  "risk_score": 0.29876668946073404
}

```

Fig. 9. Access Denial through access control in a high-risk scenario.

```

2025-04-10 04:58:21,753 - INFO - iToken requested with risk_score=0.2988
2025-04-10 04:58:21,753 - ERROR - X Access denied: High risk (RA=0.2988 >  $\theta$ =0.22)
2025-04-10 04:58:21,754 - INFO - 127.0.0.1 - - [10/Apr/2025 04:58:21] "POST /oauth/token HTTP/1.1" 403 -

```

Fig. 10. OAuth 2.0 token issuance for access denial in a high-risk scenario.

The results obtained from the experiments shown in Figs. 9 and 10 are summarized in Table 12.

In this case, ACM is calculated as 0.405, which is the product of the corresponding weights for user (0.5), database (0.9), and execute privilege (0.9). Additionally, as shown in Table 12, the total contribution value for this high-risk situation is 0.7378. By multiplying ACM value by the total contribution value, the resulting RA is 0.2988, which confirms that access was denied based on the predefined risk threshold. Here, the term “Contribution” refers to the numerical value indicating the extent to which each context element influences the final RA result. This analysis is visualized in Fig. 11. As shown in Fig. 11, the context elements that had the most significant impact on the RA value of 0.2988 were Location and Connection Type. This result demonstrates that the closer $W_{i,j}$ is to the threshold value μ of the sensitivity response function $\varphi(x)$, the more sensitively the system responds, which aligns with the theoretical explanation provided in Section 4.1.

In the previous high-risk scenario, it was confirmed that access was denied by comparing the calculated RA value with the predefined threshold. While conventional access control relies on statically issued access tokens, regardless of changes in user context, the proposed framework dynamically issues access tokens based on real-time user context information. This approach enables flexible and adaptive access control, allowing the system to effectively respond to potential threats, such as unauthorized access by attackers or misuse of personal information.

Next, an experiment was conducted under normal circumstances. In this experiment scenario, it was assumed that the user requested a general task from the AI chatbot during working hours while connected through the internal network. As defined earlier, the risk threshold was set to 0.22. In this case, if the risk assessment result is lower than the threshold value of 0.22, it indicates that the system grants a Full Access Token, allowing the requested task to be processed without restriction. As shown in Figs. 12 and 13, RA value derived in this normal situation was 0.0459, which is below the predefined threshold. Consequently, it was confirmed that a Full Access Token was issued, enabling the RPA system to execute the requested task automatically. Based on the results shown in Figs. 12 and 13, the outcomes of the experiment conducted under normal circumstances are summarized in Table 13.

Here, ACM value is calculated as 0.075, which is the product of the weights assigned to the user (0.5), internal network (0.5), and read operation (0.3). Given that the total sum of Contribution values is 0.6124, multiplying these values results in RA score of 0.0459. Since this value is lower than the predefined threshold of 0.22, it confirms that Full Access permission is granted.

When organizing the Contribution values based on the data in Table 13, the results can be visualized as shown in Fig. 14. As illustrated in Fig. 14, the contextual factors that had the greatest impact on the RA score of 0.0459 were Location and Connection. This supports the theoretical explanation provided earlier, demonstrating that the closer $W_{i,j}$ is to μ of $\varphi(x)$, the more sensitively the system reacts to changes in context.

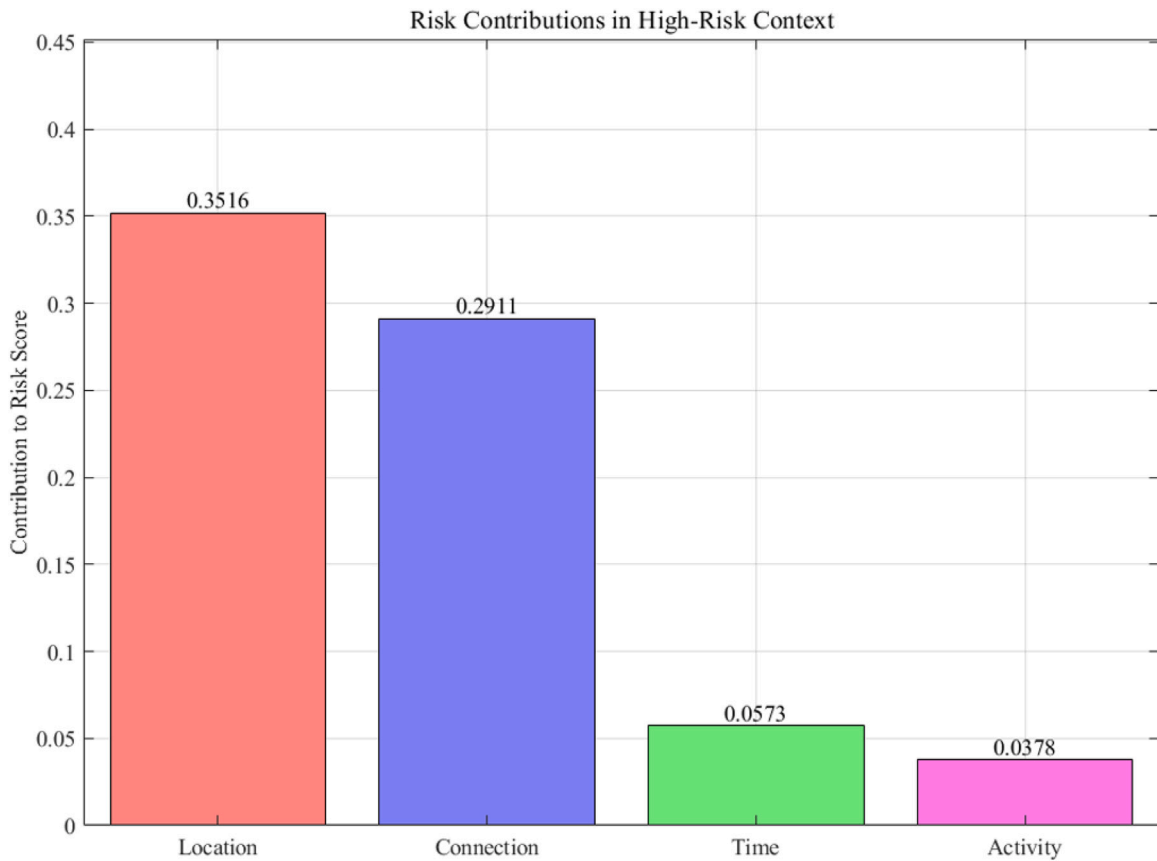


Fig. 11. Contribution of each context element to the RA value in a high-risk scenario.

```

2025-04-10 04:41:25 INFO      root - Rasa server is up and running.
Bot loaded. Type a message and press enter (use '/stop' to exit):
Your input -> /request_rpa_job
Requesting RPA job execution with OAuth 2.0 token...
RPA Job Request Received
Token: full_access_token
RA Score: 0.0459
Risk Contribution Detail:
- location: CI=0.43, W=0.69,  $\phi$ =0.7109, contribution=0.3057
- connection_type: CI=0.52, W=0.53,  $\phi$ =0.4403, contribution=0.2289
- time: CI=0.33, W=0.41,  $\phi$ =0.1493, contribution=0.0493
- activity: CI=0.60, W=0.30,  $\phi$ =0.0474, contribution=0.0285
RPA Response: Full RPA task executed.

```

Fig. 12. RPA operation based on full access permission in a normal scenario.

```

2025-04-10 04:41:37,733 - INFO - [i]Token requested with risk_score=0.0459
2025-04-10 04:41:37,733 - INFO - [✓] Access granted: Full (RA=0.0459 <  $\theta$ =0.22)
2025-04-10 04:41:37,734 - INFO - 127.0.0.1 - - [10/Apr/2025 04:41:37] "POST /oauth/token HTTP/1.1" 200 -

```

Fig. 13. Issuance of full access token by OAuth 2.0 server in a normal scenario.

Finally, Fig. 15 compares the output characteristics of the sigmoid function – which varies depending on the reference value and sensitivity settings described in Fig. 7 – with the context-based sensitivity response function derived and validated using the data in

Table 13

Risk contribution analysis results for each contextual factor in a normal scenario.

Context	CI_i	$W_{i,j}$	$\varphi(W_{i,j})$	Contribution ($CI_i \times \varphi(W_{i,j})$)
Location	0.43	0.69	0.7109	0.3057
Connection	0.52	0.53	0.4403	0.2289
Time	0.33	0.41	0.1493	0.0493
Sensitivity	0.60	0.30	0.0474	0.0285
Total	–	–	–	0.6124

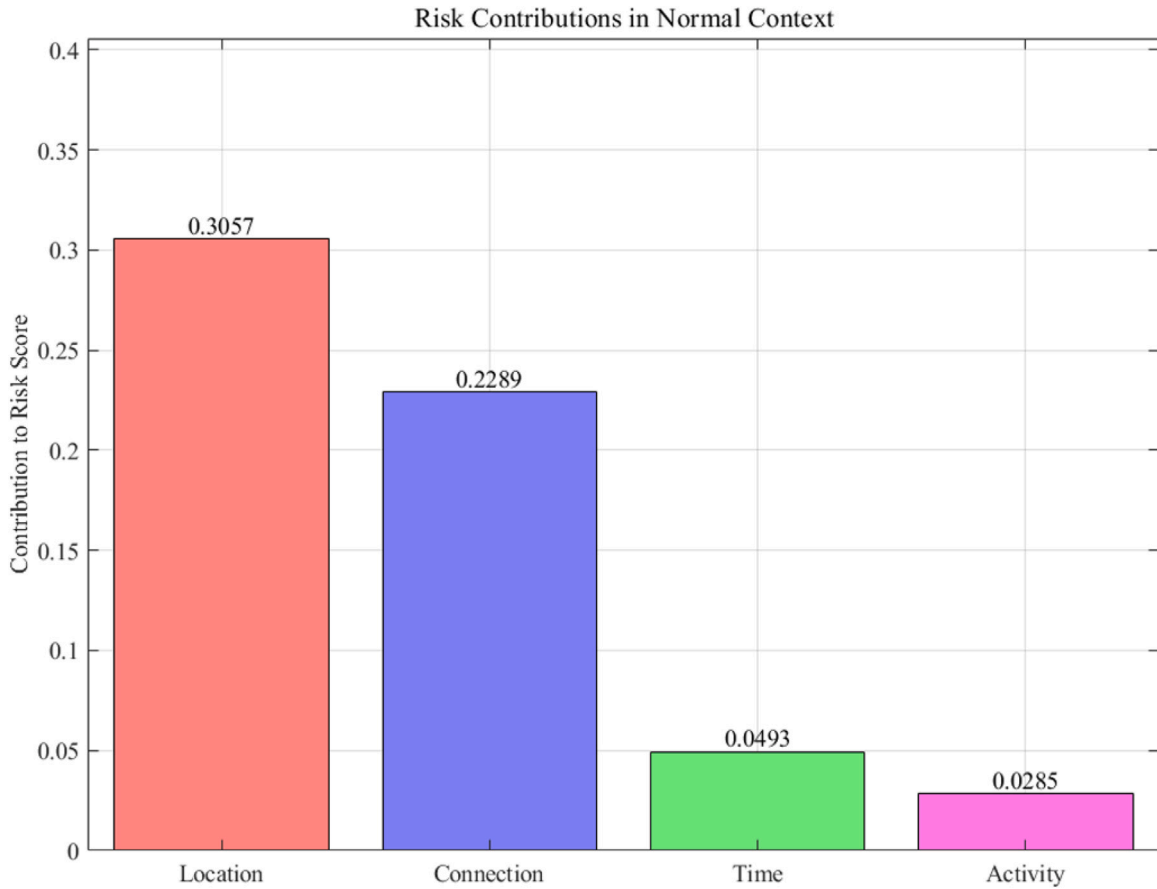
**Fig. 14.** Contribution of each context to the *RA* value in normal scenario.

Table 11. Based on Table 11, it was demonstrated that policy-driven sensitivity can be effectively adjusted by tuning the reference values and sensitivity parameters. In the experiment, the sensitivity functions for each context were visualized using distinct colors: orange (location), brown (access), pink (time), and purple (activity). As shown in Fig. 15, the sensitivity for each task exhibits a sharp increase near the threshold value, indicating that task sensitivity responds rapidly once the threshold is exceeded.

This demonstrates that the proposed framework is capable of performing situational risk assessments that dynamically reflect the user's context, rather than relying on static, predefined risk evaluations. As a result, it can flexibly adapt to environments where conditions frequently change. Consequently, even if an attacker obtains the user's sensitive information or authentication credentials, the proposed system's context-aware and adaptive access control can help mitigate security threats, such as unauthorized system takeover attempts.

4.3. Security analysis

The proposed framework is designed to address authentication protocols, making it crucial to demonstrate its practical effectiveness against security threats. Accordingly, this section uses a DFD to illustrate how data is input, processed, stored, and output within each entity of the proposed framework. It then models threats based on STRIDE and analyzes security feasibility through actual simulations.

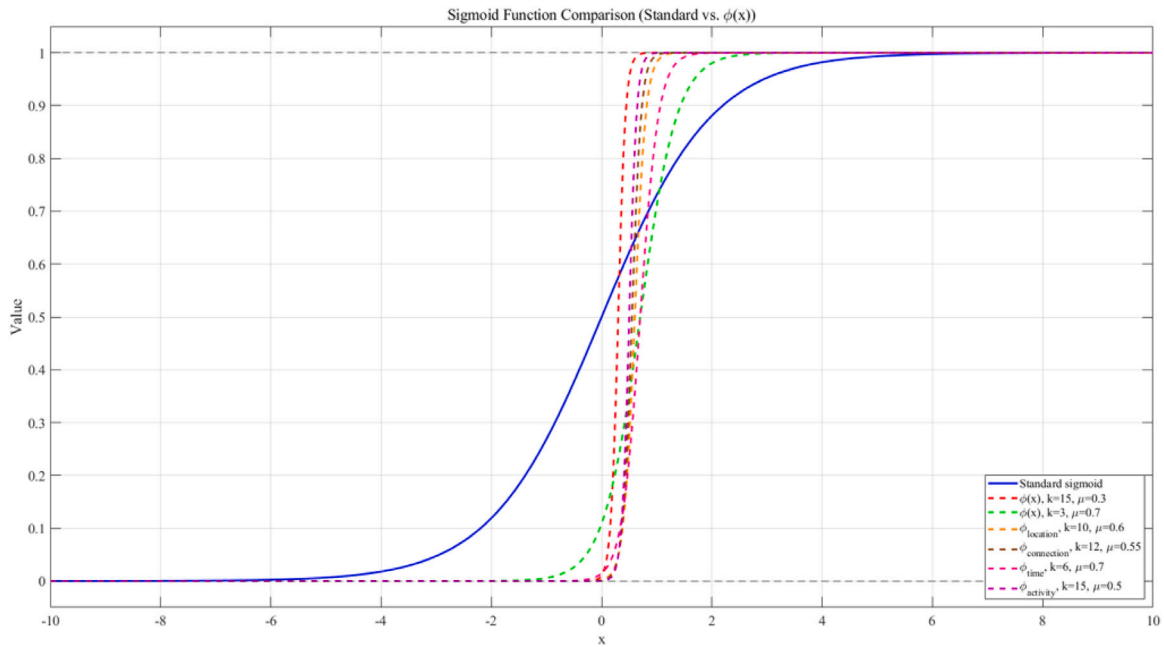


Fig. 15. Comparison between standard Sigmoid function and context-based sensitivity function.

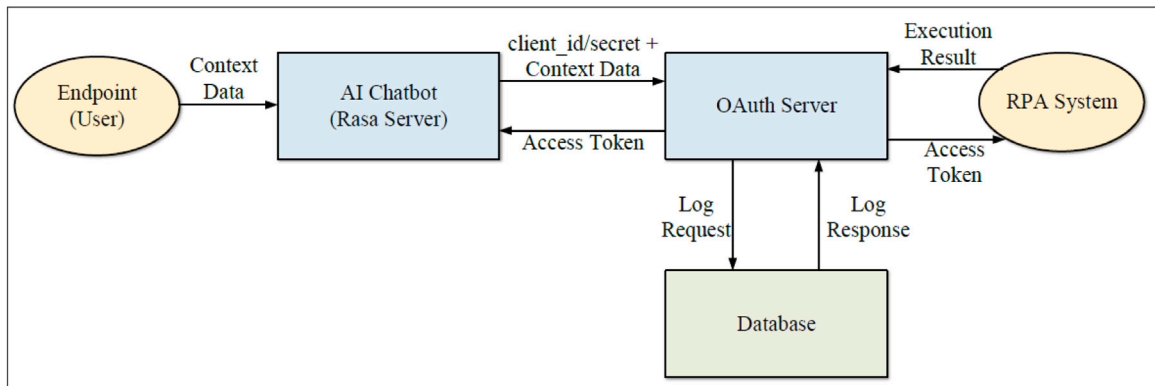


Fig. 16. DFD diagram of the proposed framework.

For the proposed framework, the external entities are the Endpoint and RPA Server. The internal processes include the AI chatbot and OAuth Server, with SQLite DB serving as the data storage. Accordingly, the data flow involves inputting request information along with context data from the Endpoint through the AI chatbot. The AI chatbot transmits the context information along with the credential data to the OAuth Server. The OAuth Server then performs a risk assessment, issues an Access Token, and simultaneously records all request details in the DB. Subsequently, the issued Access Token is transmitted to the RPA Server. When the actual request task is executed, the result is returned to the user. Based on this sequence of operations, the DFD can be depicted as shown in Fig. 16.

Using Fig. 16, the STRIDE threat model was applied. By mapping the potential attack surfaces for each threat category onto the DFD, the STRIDE security threats capable of executing the actual threats were simulated. First, for Spoofing attacks, we performed attacks involving incorrect input of credentials transmitted between the user and the OAuth Server. For Tampering attacks, we simulated scenarios where tampered context data (in JSON format) was transmitted between the AI chatbot and the OAuth Server. The Repudiation attack assessed the possibility of a user denying their actions. The Information Disclosure threat checked whether the responses issued by the OAuth Server regarding tokens contained sensitive information. For the DoS threat, we verified whether the system could handle a malicious user performing continuous requests over a short period. For Elevation of Privilege threats, we verified the system's ability to respond when an attacker attempts to obtain a full access token based on a dangerous context. Simulations confirmed that the system can achieve results as shown in Fig. 17.

[Spoofing] Mitigated Latency=17.74 ms, CPU=0.00%, Mem=64.00 MB
↳ Explanation: Invalid credentials blocked → unauthorized user cannot obtain token
[Tampering] Mitigated (Invalid Context) Latency=8.94 ms, CPU=0.00%, Mem=64.00 MB
↳ Explanation: Malformed context detected → risk evaluation downgraded access
[Repudiation] Mitigated (Logged) Latency=10.35 ms, CPU=0.00%, Mem=64.00 MB
↳ Explanation: Request recorded in requests_log table
[InfoDisclosure] No sensitive data leaked Latency=5.90 ms, CPU=0.00%, Mem=64.00 MB
↳ Explanation: Response payload contained no sensitive identifiers
[DoS] Resilient Average latency=6.08 ms
↳ Explanation: High request load did not degrade performance
[ElevationOfPrivilege] Mitigated Latency=6.31 ms, CPU=0.00%, Mem=64.00 MB
↳ Explanation: High-risk context produced Limited/Denied token → privilege escalation blocked

Fig. 17. Results of security threats simulation for the proposed framework.

75	1756912654.1620224	[{"location": "Cl_1", "connection_type": "C2_1", "time": "C3_1", "activity": "C4_1"}]	Denied (Invalid credentials)	N/A
76	1756912751.5135524	wrong_id[{"location": "Cl_0"}]	Denied (Invalid credentials)	N/A
77	1756912751.5316327	Ov231isFzpfHn5s8XKO4	[{"location": "MALFORMED"}]	Full access full_access_token
78	1756912751.541092	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
79	1756912751.5518699	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
80	1756912751.5580127	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
81	1756912751.5659604	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
82	1756912751.5721576	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
83	1756912751.5775607	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
84	1756912751.5833914	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
85	1756912751.589257	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
86	1756912751.5953302	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
87	1756912751.6007087	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
88	1756912751.606635	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
89	1756912751.6123207	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
90	1756912751.6186168	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
91	1756912751.6237905	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
92	1756912751.6292737	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
93	1756912751.6356196	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
94	1756912751.6415346	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
95	1756912751.6474981	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
96	1756912751.6537244	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token
97	1756912751.65904	Ov231isFzpfHn5s8XKO4	[{"location": "Cl_0"}]	Full access full_access_token

Fig. 18. Log records of user requests in the proposed framework.

As shown in Fig. 17, the proposed framework demonstrates resilience against all attacks. Specifically, for Spoofing attacks, when a user enters an incorrect client_id and client_secret, the proposed framework itself refuses to issue an Access Token and logs 'Invalid credential blocked' in the database. This demonstrates that it can block the very attempt of an external attacker to gain access by spoofing credentials. For tampering attacks, when receiving a modified JSON, the framework issues a Limited Access Token instead of a Full Access Token, thereby preventing the potential for damage to escalate. Furthermore, the proposed framework stores all logs, including both legitimate and malicious requests, as shown in Fig. 18. This prevents users from claiming they did not perform certain requests under specific circumstances, confirming the proposed framework provides irreversible audit trail functionality. Regarding the Information Disclosure threat, as seen in the OAuth Server's response results, it only contains the Access Token, descriptions of risk factors, and performance metrics, but does not include any PII information.

Consequently, it can be confirmed that the proposed framework adheres to the principle of minimal information disclosure when generating responses to specific requests. To verify resilience against DoS attacks, a total of 20 requests were executed consecutively within a short timeframe. Stable performance was observed in terms of response time, CPU utilization, and memory usage. Finally, regarding Elevation of Privilege threats, Fig. 17 confirms that when an attacker attempted to combine malicious contexts to issue a Full Access Token, the proposed framework did not issue a Full Access Token but instead issued a Limited or Denial Access Token. This demonstrates that the proposed framework can block privilege escalation attempts. The simulation results were finally summarized in relation to the DFD as shown in Table 14. This demonstrates that the proposed framework can respond to STRIDE threats, enabling the minimization of damage when security threats occur.

5. Discussion

As the demand for anytime, anywhere service access continues to grow, AI-based automation has become a necessity rather than a choice [31]. In response, RPA, originally centered on manufacturing tasks, has evolved into a 24/7 service delivery framework by integrating with AI Chatbots and is now being widely adopted across various industries.

In particular, the convergence with generative AI technologies has enabled automation to extend beyond simple repetitive tasks to encompass more complex, high-level operations. However, as these systems begin to handle tasks involving access to sensitive

Table 14

STRIDE threat scenarios and mitigation results of the proposed framework.

STRIDE threat	Related DFD element	Attack simulation method	Mitigation result
Spoofing	Endpoint ↔ OAuth Server	Transmission of incorrect <i>client id/secret</i>	✓ (Mitigated)
Tampering	AI Chatbot ↔ OAuth Server	Transmission of manipulated request content	✓ (Mitigated)
Repudiation	OAuth Server ↔ Database	Logging all requests to the DB to prevent denial	✓ (Mitigated)
Information disclosure	OAuth Server ↔ AI Chatbot	Verification that no PII-containing data is included in access tokens	✓ (No Sensitive Data Leaked)
Denial of Service	Endpoint ↔ OAuth Server	Detection of latency caused by 20 consecutive requests	✓ (Resilient)
Elevation of Privilege	OAuth Server	Execution of requests based on crafted test vectors	✓ (Mitigated)

information or requiring precise decision-making, security threats have emerged as a critical concern. In such architectures, verifying the legitimacy of users becomes a core challenge. Current systems often lack sufficient identity verification mechanisms, leaving them vulnerable to impersonation attacks in which adversaries can exploit the system by masquerading as legitimate users.

This paper proposes an OAuth 2.0 based integrated authentication framework designed to enable precise access control based on user context with minimal information disclosure, addressing these security concerns. This framework resolves the limitations of existing ID/PWD and PKI methods, such as SPoF caused by centralized storage and privacy violations due to excessive personal information submission, through the use of DID technology. Furthermore, by utilizing the DID:web approach, users can selectively provide only necessary information, thereby protecting their privacy. In the proposed framework, after DID authentication is completed, an access token is issued based on OAuth 2.0 to perform access control. However, existing OAuth 2.0 has limitations in reflecting user context. To address this, the proposed framework evaluates risk levels based on metadata such as the user's location information and connection type, dynamically controlling access permissions. A sigmoid based formula is used to implement risk assessment that reacts sensitively to changes in user context. The design allows flexible adjustment of security levels according to administrator settings through policy thresholds and sensitivity parameters.

This structural integration fundamentally overcomes the limitations of existing OAuth 2.0 and PKI authentication systems. Authentication and access control are integrated into an automated flow, enabling secure processing without complex authentication procedures. Furthermore, the DID approach offers substantial privacy protection advantages by not storing authentication information in a central repository, allowing users to present only necessary information. It also provides security against SPoF.

Additionally, we verified whether the proposed framework can safely respond to and minimize damage when facing actual cybersecurity threats through simulations based on DFD and STRIDE threat scenarios. Simulations based on STRIDE threat scenarios demonstrated that the proposed framework can mitigate all security threats. This was confirmed with an average latency of 9.22 ms and memory usage of 64.00 MB, indicating advantages in terms of security, real-time capability, and lightweight design.

Based on these characteristics, the proposed framework can be applied to overall AI chatbot-based RPA systems, but its necessity is particularly greater in the financial, healthcare, and public service sectors where PII protection is critical. For example, Heritage Bank in the US protects sensitive account information through AI-based RPA and a separate authentication system. In Cognizant's KYC/AML automation case, user authentication and context-based access control also served as core requirements [32,33]. This simultaneously demonstrates the necessity for precise authentication and access control in systems handling sensitive information and the applicability of this framework.

However, the proposed framework may have some limitations regarding user convenience. Some users may perceive that as the security level increases, the authentication process becomes more complex or time-consuming, leading to resistance toward adopting the system. In particular, multi-factor authentication and risk-based control structures implemented for enhanced security can be perceived as cumbersome and counterintuitive by some users. There is also the possibility that such authentication procedures could negatively impact the user experience (UX). To address this, the proposed framework is designed to perform authentication procedures with minimal user intervention through an integrated authentication flow and a context-based automatic judgment structure. However, future research should take this a step further. Based on user-centered authentication flow design and UX evaluation, it is necessary to also consider optimization strategies for the security interface that can finely balance security and usability.

In the long term, it is possible to expand the proposed framework into a self-evolving structure by linking the risk assessment and certification flow with trainable AI models. Alternatively, integration with policy optimization algorithms capable of coordinating conflicting policies and deriving optimal response paths could be considered. This direction is expected to serve as the foundation for evolving the proposed structure beyond a simple static policy-based system into a dynamic security system capable of actively adapting to changing environments. This approach goes beyond merely automating current policy application methods; by introducing real-time feedback-based self-learning and adaptive mechanisms, it can also contribute to enhancing proactive response capabilities against evolving threat landscapes. Finally, the proposed framework represents a new paradigm that combines context-based risk assessment to address the limitations of existing OAuth 2.0 technology. As this approach is rarely implemented in existing systems, there are inherent limitations in presenting direct adoption trends through benchmarking based on commercial systems. However, due to the open-source nature of the RASA model, it can be enhanced through design and implementation tailored to each enterprise infrastructure. Consequently, the proposed framework offers advantages in flexibility and scalability, indicating its potential to become a core engine across multiple industries. Given the recent trend of increasing cases aiming to build RPA systems based on AI chatbots, the proposed framework demonstrates high value by implementing a flexible framework based on the standard OAuth 2.0 technology, which is not limited to specific chatbot platforms. Consequently, an increase in technical demand across various industrial sectors can be anticipated.

6. Conclusion

In this paper, we have proposed the OAuth 2.0 integrated authentication framework that leverages a context-based risk assessment approach to enhance security in AI chatbot-based RPA systems. The proposed framework aims to reduce the likelihood of security threats and minimize potential damage by providing only the minimum necessary user information while simultaneously enforcing access control based on the user's current context.

In the proposed framework, distributed identity authentication using the DID:web method is applied to overcome the limitations of traditional ID/password-based authentication and PKI-based certificate authentication methods. This approach enables user authentication based on only the minimum necessary information, without exposing unnecessary personal data. This is particularly significant, as it prevents user personal information from being stored or processed within the AI chatbot system, thereby reducing the risk of personal information leakage or misuse even if an attacker compromises the AI chatbot. Furthermore, to address the limitation that AI chatbot-based RPA systems depend solely on user judgment when performing sensitive tasks or accessing important files, the proposed framework introduces context-based risk assessment. By calculating a risk score based on the user's current context and comparing it against internal security policies, the system dynamically determines whether to issue an access token through the OAuth 2.0 authentication framework. This mechanism ensures that even if an attacker obtains the user's authentication information, the likelihood of successfully performing unauthorized actions is significantly reduced.

However, the proposed framework has certain limitations, particularly in that its risk assessment model is relatively simple, and the threshold value used for risk evaluation must be configured manually. To address these limitations and better meet the requirements of automated services, future work aims to develop a more advanced risk assessment model that leverages AI technology to analyze user context. In addition, we plan to introduce mechanisms that enable dynamic threshold adjustment, either by analyzing time-series log data or by applying RBAC policies, to enhance the flexibility and adaptability of the risk assessment process.

Declaration of competing interest

The authors declare the following financial interests/personal relationships which may be considered as potential competing interests: Jong-Hyoun Lee reports financial support was provided by Korea Creative Content Agency. If there are other authors, they declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This research was supported by the Culture, Sports and Tourism R&D Program through the Korea Creative Content Agency grant funded by the Ministry of Culture, Sports and Tourism in 2025 (Project Name: Training Global Talent for Copyright Protection and Management of On-Device AI Models, Project Number: RS-2025-02221620, Contribution Rate: 100%).

Data availability

No data was used for the research described in the article.

References

- [1] TextYesS. The relevance of having an AI chatbot to offer 24/7 shopping assistance. 2025, [Online]. Available: <https://www.textyess.com/en/blog/article3>. [Accessed 10 April 2025].
- [2] AI chatbot global market report 2025. The Business Research Company, [Online]. Available: <https://www.thebusinessresearchcompany.com/report/artificial-intelligence-ai-chatbot-global-market-report>. [Accessed 10 April 2025].
- [3] LayerX Security. AI chatbot security explained. 2025, [Online]. Available: <https://layerxsecurity.com/learn/chatbot-security/>. [Accessed 10 April 2025].
- [4] Botpress. Chatbot security guide: Risks & guardrails. 2025, [Online]. Available: <https://botpress.com/blog/chatbot-security>. [Accessed 11 April 2025].
- [5] Sebastian G. Do ChatGPT and other AI chatbots pose a cybersecurity risk?: An exploratory study. *Int J Secur Priv Pervasive Comput* 2023;15(1):1–11.
- [6] Wang Y, Pan Y, Yan M, Su Z, Luan TH. A survey on ChatGPT: AI-generated contents, challenges, and solutions. *IEEE Open J Comput Soc* 2023;4:280–302.
- [7] Kwon S, Park J, Lee T, Oh S, Lee JH. Decentralized identifier based illegal digital content distribution tracking system using the format-preserving encryption algorithm. *Softw Pr Exp* 2024;54(7):1275–93.
- [8] TechTarget. Attended vs. unattended RPA bots: Key differences. 2025, [Online]. Available: <https://www.techtarget.com/searchcio/tip/RPA-bots-Unattended-vs-attended-vs-hybrid>. [Accessed 11 April 2025].
- [9] Webisof. AI-based chatbot. 2025, [Online]. Available: <https://webisof.com/articles/ai-based-chatbot/>. [Accessed 01 August 2025].
- [10] James C. Securing bot credentials and sensitive information in robotic process automation (RPA). 2023.
- [11] NIST. Information leakage. 2025, [Online]. Available: https://csrc.nist.gov/glossary/term/information_leakage. [Accessed 01 August 2025].
- [12] Choudhary S, et al. How not to detect prompt injections with an LLM. 2025, arXiv preprint [arXiv:2507.05630](https://arxiv.org/abs/2507.05630).
- [13] NIST. NIST identifies types of cyberattacks that manipulate the behavior of AI systems. 2025, [Online]. Available: <https://www.nist.gov/news-events/news/2024/01/nist-identifies-types-cyberattacks-manipulate-behavior-ai-systems>. [Accessed 01 August 2025].
- [14] Cloudflare. OWASP top 10 risks for LLMs. 2025, [Online]. Available: <https://www.cloudflare.com/learning/ai/owasp-top-10-risks-for-llms/>. [Accessed 01 August 2025].
- [15] Ahadian P, Guan Q. A survey on hallucination in large language and foundation models. 2025.
- [16] Paul C. Security implications of unattended vs. Attended RPA bots. 2023.

- [17] Hardt D. The oauth 2.0 authorization framework. 2025, RFC 6749, [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc6749>. [Accessed 11 April 2025].
- [18] Fett D, Küsters R, Schmitz G. A comprehensive formal security analysis of oauth 2.0. In: Proc. 2016 ACM SIGSAC conf. comput. commun. secur. CCS, 2016, p. 204–1215.
- [19] Ferry E, O'Raw J, Curran K. Security evaluation of the oauth 2.0 framework. *Inf Comput Secur* 2015;23(1):73–101.
- [20] Philippaerts P, Preuveneers D, Joosen W. Oauch: Exploring security compliance in the oauth 2.0 ecosystem. In: Proc. int. symp. res. attacks intrusions defenses. RAID, 2022, p. 460–81.
- [21] Internet Engineering Task Force (IETF). OAuth 2.0 threat model and security considerations. 2025, [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6819>. [Accessed 20 July 2025].
- [22] Luo K, et al. Universal cross-app attacks: Exploiting and securing oauth 2.0 in integration platforms. 2023.
- [23] Ramić ŠB, Cogo E, Prazina I, Cogo E, Turkanović M, Mulahasanović RT, Mrdović S. Selective disclosure in digital credentials: A review. *ICT Express* 2024;10(4):916–34.
- [24] Chiu WY, Meng W, Jensen CD. Chainpki—towards ethash-based decentralized PKI with privacy enhancement. In: Proc. IEEE conf. dependable secure comput. DSC, 2021, p. 1–8.
- [25] Cho KW, et al. Decentralized self-sovereign identity model providing secure de-identification and external sharing of data (Ph.D. dissertation), Pukyong National Univ.; 2022.
- [26] Singh G, Singh G. Coefficient bounds for a generalized subclass of bounded turning functions associated with sigmoid function. *Int J Nonlinear Anal Appl* 2023;14(11):1–10.
- [27] Wang M, et al. A high-speed and low-complexity architecture for softmax function in deep learning. In: Proc. IEEE Asia Pacific conf. circuits syst. APCCAS, 2018, p. 223–6.
- [28] Zheng H, et al. Adaptive friction in deep learning: Enhancing optimizers with sigmoid and tanh function. In: Proc. 2024 IEEE 6th int. conf. power, intell. comput. syst. ICPICS, 2024, p. 809–13.
- [29] Bai Y. Relu-function and derived function review. In: SHS web conf. vol. 144, 2022, p. 02006.
- [30] Bishop CM. Pattern recognition and machine learning. 4th ed.. New York, NY, USA: Springer; 2006.
- [31] Sarker IH, Janicke H, Mohsin A, Gill A, Maglaras L. Explainable AI for cybersecurity automation, intelligence and trustworthiness in digital twin: Methods, taxonomy, challenges and prospects. *ICT Express* 2024;10(4):935–58.
- [32] Akvelon. AI for PII management in fintech: Balancing innovation and PII protection. 2025, [Online]. Available: <https://akvelon.com/ai-for-pii-management-in-fintech-balancing-innovation-and-pii-protection/>. [Accessed 20 July 2025].
- [33] Algorithmic impact assessment: A Case Study in Healthcare. Ada Lovelace Institute, [Online]. Available: <https://www.adalovelaceinstitute.org/report/algorithmic-impact-assessment-case-study-healthcare/>. [Accessed 20 July 2025].